Construindo um HSM de brinquedo

Como funciona um módulo criptográfico de hardware, aprendido de dentro para fora

Projeto hsm-a7 — Artix-7 XC7A35T

Sumário

Parte I — O que é um HSM

1. O problema que um HSM resolve
2. Modelo de ameaça
3. As três propriedades
4. Onde HSMs são usados

Parte II — Arquitetura interna

5. A fronteira criptográfica
6. Hierarquia de chaves
7. Cerimônia de chave, split knowledge e dual control
8. Key blocks: por que o formato é feio
9. Máquina de estados: a chave de switch
10. Aleatoriedade: onde HSM vira ciência
11. Self-test: por que o dispositivo se recusa a funcionar
12. Zeroização: apagar é mais difícil do que parece
13. Log de auditoria: por que antes, não depois
14. Ciclo de vida de uma chave

Parte III — Como HSMs são atacados

15. Ataques de API — o mais importante
16. Canais laterais
17. Injeção de falha
18. Ataques físicos e antitamper

Parte IV — Certificação

19. FIPS 140-3
20. PCI: as regras de pagamentos
21. Common Criteria
22. O que "certificado" significa — e o que não significa

Parte V — O projeto hsm-a7

23. Objetivo, plataforma e restrições
24. Fase 1, peça por peça
25. Resultados medidos
26. Três lições que a Fase 1 ensinou fazendo

Parte VI — O caminho adiante

27. Fase 2 — engines e self-test *(concluída)*
28. Fase 3 — hierarquia de chaves *(em andamento)*
29. Fase 4 — armazenamento não-volátil *(em andamento)*
30. Fase 5 — API de host *(em andamento)*
31. Fase 6 — tamper e ataques
32. Fase 7 — assimétrico
33. Fase 8 — criptografia de pagamento

34. Ordem de trabalho, e a regra que a sustenta

Parte VII — Criptografia de pagamento

35. PIN blocks — por que um PIN não viaja sozinho
36. Tradução de PIN — o comando mais perigoso que existe
37. Verificação de PIN — PVV e IBM 3624
38. DUKPT — uma chave por transação
39. O que este projeto pode e o que não pode ensinar

Apêndices

A. Glossário
B. Especificação do protocolo
C. Pinagem
D. Reproduzir o trabalho
E. Operar o dispositivo
F. Leitura

Sobre este documento

Este é o material de um projeto didático: construir, do zero, um módulo criptográfico com hierarquia de chaves, cerimônia de carga, key blocks e API de host — reproduzindo a arquitetura de um HSM real em escala reduzida, num FPGA Artix-7.

O documento tem duas metades que se encontram no meio. As Partes I a IV explicam **como um HSM funciona e por quê**, independentemente deste projeto: arquitetura, ameaças, ataques históricos e certificação. A Parte V explica **o que foi construído** e liga cada peça de código ao conceito correspondente. A Parte VI é o roteiro do que falta. A Parte VII trata do domínio para o qual o projeto passou a apontar: **criptografia de pagamento** — PIN blocks, tradução de PIN, verificação por PVV e 3624, DUKPT — e diz, sem rodeio, o que deste domínio é ensinável aqui e o que não é.

Estado na data desta edição: **Fases 1 e 2 completas e validadas em hardware** — AES-256, SHA-256, HMAC, CMAC, TRNG com health tests da SP 800-90B e CTR_DRBG, todos verificados contra vetores oficiais do NIST e do IETF, com POST rodando a cada boot e levando o dispositivo a `TAMPERED` se reprovar.

Fase 3 em andamento, e adiantada: o key store em BRAM existe, com 16 slots modelados nos campos do cabeçalho X9.143 e a chave mestra em região separada; a **cerimônia de carga** também — três componentes por XOR, KCV conferido a cada passo e dual control exigindo dois botões físicos, com a escada `UNINITIALIZED → AUTHORIZED → OPERATIONAL`.

E o que faltava quando esta linha foi escrita pela primeira vez já não falta: o **key block ANSI X9.143**, implementado duas vezes — em C dentro do dispositivo e em Python no host, sobre bibliotecas diferentes, para que as duas discordem quando alguém ler a norma errado; o **zeroize**, que apaga e *prova* que apagou; e os **comandos que manipulam chave** — gerar, exportar embrulhado, reimportar, consultar metadados.

Falta apagar um slot isolado (a função existe, o comando não), usar chave por handle, e o log de auditoria. O apêndice E.7 lista isso sem rodeios.

Quem quer só entender o assunto pode parar na Parte IV — ou seguir para a VII, se o interesse for pagamento. Quem quer reproduzir o trabalho começa na Parte V e volta às anteriores conforme a dúvida aparecer. Quem tem a placa na mão e quer operá-la vá direto ao **apêndice E**, que percorre uma sessão inteira: ligar, autoteste, cerimônia, ativação e o trabalho com chaves.

AVISO — este dispositivo não é um HSM

Não há PUF, malha antitamper, sensores físicos, gerador de números aleatórios certificado, nem qualquer validação FIPS, PCI ou Common Criteria. As chaves ficam numa BRAM que qualquer um com o bitstream pode inspecionar em simulação.

O objetivo é **entender a arquitetura de dentro para fora**, não proteger material de chave real. Nenhuma chave de produção deve jamais ser carregada neste dispositivo.

A honestidade sobre isso não é modéstia: saber exatamente **por que** este aparelho não é seguro é metade do aprendizado. Cada ausência listada na seção 22 corresponde a um mecanismo real que existe num HSM de verdade e custa dinheiro, tempo de projeto e meses de avaliação.

Licença. Este manual e o código do projeto estão sob a **Apache License 2.0**. O texto integral está em `LICENSE`, no repositório.

Independência. Este documento não nomeia fabricante nem produto de HSM, e não há vínculo, patrocínio, endosso ou alegação de compatibilidade com equipamento comercial algum. O conteúdo vem de normas públicas — ISO, ANSI, NIST, IETF — e de literatura acadêmica publicada; nada é derivado de documentação proprietária. Ver `THIRD-PARTY.md`.

Parte I — O que é um HSM

1. O problema que um HSM resolve

Software comum guarda chaves na memória do processo. Quem tem acesso à máquina — o usuário `root`, um dump de memória, um bug de leitura fora de limites, um backup mal apagado — tem a chave. E há uma consequência mais sutil: **não existe forma de distinguir "usar a chave" de "copiar a chave"**. Se o programa consegue assinar, o programa consegue exportar o segredo que assina. Quem controla o programa herda essa capacidade.

Um HSM (*Hardware Security Module*) existe para tornar essas duas coisas diferentes. Ele oferece uma **interface de operações**, não de acesso:

```
    o host manda:  "assine este bloco com a chave 7"
    o host nunca manda:  "me devolva a chave 7"
```

A chave nasce dentro do dispositivo, vive dentro e morre dentro. Ela pode sair — mas só embrulhada (*wrapped*) por outra chave que também nunca saiu.

Essa separação parece pequena e reorganiza tudo. A pergunta de segurança deixa de ser *"quem consegue ler a memória?"* e passa a ser:

> ***O que a API permite deduzir sobre a chave, se for chamada um milhão de vezes com entradas escolhidas pelo atacante?***

Praticamente toda a arquitetura descrita neste documento decorre dessa pergunta. É também por isso que os ataques mais interessantes contra HSMs não quebram criptografia: eles conversam com a API.

Um exemplo concreto

Imagine um banco que precisa verificar PINs de cartão. O PIN correto é derivado do número da conta com uma chave secreta. Sem HSM:

- a chave de derivação está na memória do servidor de autorização;
- qualquer comprometimento desse servidor entrega a chave;
- com a chave, o atacante calcula o PIN de **qualquer** conta, offline, sem deixar rastro e sem limite de tentativas.

Com HSM:

- a chave está dentro do módulo e nunca esteve em outro lugar;
- o servidor manda “este PIN confere para esta conta?” e recebe sim ou não;
- comprometer o servidor dá ao atacante a capacidade de **perguntar**, não a chave. Perguntas são contadas, limitadas e registradas.

O atacante não é impedido — ele é **reduzido a um canal estreito, medido e auditável**. Essa redução é o produto que um HSM vende.

2. Modelo de ameaça

“Seguro” não significa nada sem dizer contra quem. HSMs são projetados contra uma escada de adversários, e cada degrau custa mais caro de defender.

Adversário	Capacidade	Defesa correspondente
Aplicação comprometida	Chama a API à vontade	Máquina de estados, atributos de chave, limites de uso
Administrador do host	Root na máquina, vê todo o tráfego do canal	Chaves nunca no host; autorização física no próprio módulo
Insider com acesso físico	Toca no equipamento, opera o painel	Dual control, split knowledge, log de auditoria
Atacante com o aparelho na mão	Bancada, osciloscópio, fonte de alimentação	Antitamper, sensores, canal lateral, injeção de falha
Laboratório especializado	Decapsulação, microssonda, FIB	Malha ativa, camadas de blindagem, zeroização por detecção

Duas observações que orientam o resto do documento.

O host é hostil por premissa. Não é que se desconfie do host — é que a arquitetura não pode *depender* de ele estar íntegro. É por isso que autorização de operações sensíveis é feita com **botões no próprio equipamento**, e não com um comando “eu autorizo” que chega pelo cabo. Um comando pelo cabo tem exatamente a confiabilidade do host que o enviou.

A escada é econômica, não absoluta. Nenhum HSM é inviolável. O objetivo é tornar o ataque mais caro que o valor protegido, e detectável quando tentado. Um módulo que resiste seis meses a um laboratório nacional e falha contra ele no sétimo mês pode estar perfeitamente adequado, se as chaves tiverem rotação trimestral.

3. As três propriedades

Tudo que um HSM faz se organiza em três propriedades. Elas são interdependentes: qualquer uma sozinha é inútil.

Confinamento

Existe uma fronteira física, e material de chave em claro não a atravessa. Dentro: chaves, estado do gerador aleatório, segredos derivados. Fora: criptogramas, chaves embrulhadas, valores de verificação, identificadores, log.

Confinamento sem mediação é um cofre com a porta aberta.

Mediação

Toda operação passa por verificação de política **antes** de executar: o dispositivo está no estado certo? Há autorização suficiente? Esta chave tem permissão para esta operação? O pedido é bem formado?

Mediação sem confinamento é uma sugestão — se a chave pode ser lida por fora, a verificação é decorativa.

Evidência

O que aconteceu fica registrado de forma que sobreviva à falha e não possa ser reescrito para omitir a tentativa.

Sem evidência, você nunca descobre se as outras duas falharam. E é a propriedade mais frequentemente subestimada: um log que registra apenas sucessos mostra um dispositivo saudável exatamente enquanto ele está sendo mapeado por um atacante, cujo trabalho produz muitos erros e poucos acertos.

4. Onde HSMs são usados

O termo cobre famílias de equipamento bastante diferentes, e saber qual é qual ajuda a entender por que este projeto modela LMK e TR-31 em vez de, digamos, PKCS#11 e certificados.

HSM de pagamentos

O mais antigo e o mais rígido. Protege PINs de cartão, chaves de terminal e criptogramas EMV. Há poucos fabricantes, e os equipamentos são certificados sob o PCI PTS HSM.

É onde nasceram os conceitos de **LMK** (chave mestra local), **key block** e a exigência operacional de dual control e split knowledge. As regras não são recomendações: PCI PIN Security e PCI PTS HSM são requisitos contratuais para quem processa transações de cartão.

O comando típico não é “assine” — é “verifique este PIN”, “traduza este PIN block desta chave para aquela”, “gere uma chave de terminal”.

HSM de propósito geral

Protege chaves de PKI, assinatura de código, TLS, bancos de dados, blockchain. Vários fabricantes, tipicamente validados em FIPS 140-3, YubiHSM.

A interface padrão é **PKCS#11** — `C_GenerateKey`, `C_Sign`, `C_WrapKey` — ou APIs próprias (JCE, CNG, KMIP). O modelo mental é o de um chaveiro com objetos que têm atributos, e os atributos é que definem o que se pode fazer com cada chave.

HSM em nuvem

AWS CloudHSM, Azure Managed HSM, Google Cloud HSM. Fisicamente são os mesmos módulos, operados pelo provedor, com o cliente controlando as chaves. O interesse conceitual está no problema novo que criam: **como você confia num módulo que não está na sua sala?** A resposta envolve atestação remota, e é uma área em movimento.

Elementos seguros e TPMs

Primos pequenos: TPM na placa-mãe, Secure Enclave, smartcard, YubiKey. Mesma ideia — chave que não sai, operação mediada — com orçamento de área, consumo e custo muito menores. Um cartão de crédito com chip é um HSM minúsculo cuja produção passa de bilhões de unidades por ano.

O que este projeto modela

O caminho de pagamentos: **LMK, key blocks TR-31, cerimônia de carga com componentes, dual control físico**. A razão é didática — é a família onde os mecanismos organizacionais (quem autoriza o quê, e como se prova) estão mais explícitos e mais bem documentados publicamente.

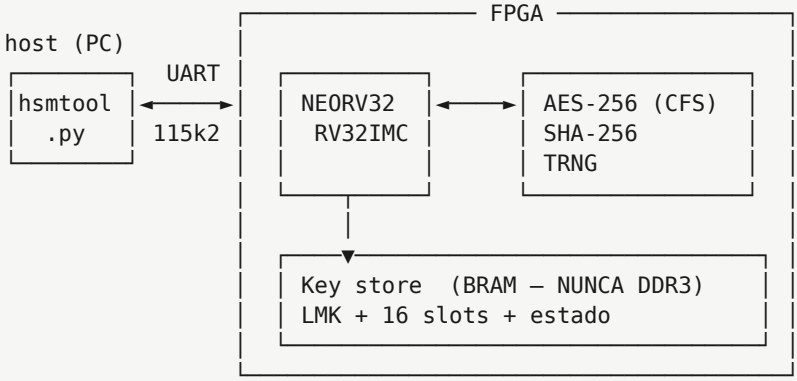
A Fase 5 do plano acrescenta a interface de host, e a escolha dela foi revista: em vez de um subconjunto de PKCS#11, um **command set ASCII** no estilo dos HSM de pagamento. Não é troca de sintaxe. PKCS#11 é uma API de *biblioteca* — objetos, sessões, atributos. Um command set de pagamento é um protocolo de *serviço*, sem sessão e sem estado do lado do cliente, e essa diferença muda como o dispositivo tem de se defender: cada comando chega sozinho e precisa se bastar.

Parte II — Arquitetura interna

5. A fronteira criptográfica

É o conceito central, e num projeto bem feito ele é literal e desenhável. Num documento de certificação FIPS existe um diagrama marcando o que está dentro, o que está fora, e uma lista de **todas** as portas que atravessam.

Neste projeto:



Dentro: LMK, chaves de trabalho em claro, estado do DRBG.

Fora: key blocks embrulhados, KCVs, criptogramas, *handles*, log.

Nada da primeira lista atravessa para a segunda. Todo comando novo é avaliado contra essa regra **antes** de ser implementado — é o único momento barato de perceber que um comando vaza.

Por que a fronteira precisa ser observável

Uma fronteira que você só pode *afirmar* não vale muito. Este projeto usa UART, e não Ethernet, precisamente por isso: a UART sai por dois pinos físicos identificáveis, e dá para prender um analisador lógico neles e capturar tudo que o dispositivo já disse.

O critério de aceitação da Fase 3 explora isso literalmente: rodar a suíte de testes inteira, capturar a UART, e fazer `grep` das chaves conhecidas do teste contra a captura. Se aparecer um byte, o projeto falhou — e você **sabe**, com evidência.

Com um stack de rede no meio, "nenhuma chave vazou" vira uma opinião sobre dezenas de milhares de linhas de código de terceiros. Com dois fios, vira uma medida.

Por que a memória importa mais do que parece

Neste projeto as chaves ficam em BRAM — memória interna ao die do FPGA. Lê-la exige decapsular o chip.

A DDR3 da placa é externa: o barramento passa por trilhas na PCB e chega a conectores de expansão. Uma ponta de prova resolve. Por isso a DDR3 não é apenas *evitada por convenção* — o barramento externo do processador está **desligado na configuração**, de modo que não existe caminho lógico do SoC até ela.

Essa é a diferença entre uma **política** e um **controle**: entre "o firmware não escreve chave na memória externa" e "não há circuito ligando o processador à memória externa". A primeira depende de todo programador futuro; a segunda, não.

6. Hierarquia de chaves

Um HSM com dezesseis slots de chave não guarda dezesseis segredos. Guarda **um** — e protege ou deriva todos os outros a partir dele.

```
LMK  (Local Master Key)
 │    nunca sai, nem embrulhada
 │
 ├── KBEK / KBAK ── derivadas por CMAC, uma por propósito
 │      │
 │      └── protegem key blocks TR-31
 │
 └── chaves de trabalho: BDK, KEK, chaves de dados, ZMK, ZPK...
```

Três razões, e vale entender cada uma porque elas explicam decisões aparentemente arbitrárias mais adiante.

Backup e migração. Se cada chave fosse independente, mover o serviço para outro HSM significaria mover N segredos, cada um com seu próprio procedimento. Com a hierarquia, você move a LMK — por cerimônia, em componentes — e todos os key blocks existentes continuam válidos, porque eles sempre foram apenas dados cifrados sob ela.

Revogação em bloco. Zeroizar a LMK invalida instantaneamente **todo** key block protegido por ela, onde quer que esteja: em backup, em fita, no servidor de outra filial. É a única operação de destruição que se consegue executar em tempo constante sobre dados que não estão na sua posse.

Separação de propósito. KBEK (chave de cifra) e KBAK (chave de autenticação) são derivadas da LMK por CMAC com rótulos distintos. A chave que cifra o corpo do key block nunca é a mesma que autentica seu cabeçalho. Se fosse, quebrar uma quebraria as duas — e existem ataques que exploram exatamente o reuso de chave entre modos de operação.

Atributos de chave

Cada chave carrega metadados que **fazem parte** dela, no sentido de que alterá-los invalida a autenticação. Estrutura usada neste projeto:

```c
typedef struct {
    uint8_t  in_use;
    uint8_t  usage[2];      // TR-31: 'B0'=BDK, 'K0'=KEK, 'D0'=dados...
    uint8_t  algorithm;     // 'A'=AES, 'T'=3DES
    uint8_t  mode_of_use;   // 'E'=cifrar, 'D'=decifrar, 'B'=ambos, 'N'=nenhum
    uint8_t  exportability; // 'E'=exportável, 'N'=não, 'S'=sensível
    uint8_t  key_len;
    uint8_t  key[32];       // BRAM. Nunca sai daqui em claro.
    uint8_t  kcv[3];
    uint32_t use_count;
} key_slot_t;
```

`exportability` é o campo que mais ensina. Uma chave marcada `'N'` não pode sair do módulo **por caminho nenhum** — nem embrulhada. Se algum comando conseguir exportá-la, o comando está errado. É exatamente o tipo de propriedade que se testa exaustivamente, porque ela vale zero se houver um único caminho esquecido.

`use_count` existe porque uso é informação: uma chave que devia ser usada mil vezes por dia e foi usada um milhão indica alguém explorando a API.

7. Cerimônia de chave, split knowledge e dual control

A LMK não é gerada num lugar e copiada para outro. Ela é **montada dentro do dispositivo**, a partir de componentes que nenhuma pessoa vê juntos.

```
    LMK = componente_A ⊕ componente_B ⊕ componente_C
```

Cada custodiante carrega apenas o seu componente. Nenhum componente isolado revela nada sobre a LMK — é o argumento do one-time pad: XOR com material desconhecido e uniforme não vaza informação. Isso é **split knowledge**.

KCV: verificar sem revelar

A cada passo, o dispositivo devolve um **KCV** (*Key Check Value*): os três bytes mais significativos do resultado de cifrar um bloco de zeros com a chave.

É um resumo pequeno o suficiente para não ajudar um atacante — 24 bits não permitem recuperar uma chave de 256 — e grande o suficiente para pegar digitação errada, componente trocado ou cartão corrompido. O host calcula o KCV esperado de forma independente e compara.

Repare no padrão: o dispositivo precisa provar que recebeu a coisa certa, sem revelar a coisa. Essa tensão reaparece o tempo todo em criptografia aplicada.

Dual control

Split knowledge diz que ninguém *sabe* a chave inteira. Dual control diz que ninguém *age* sozinho.

Neste projeto, `LMK_LOAD_COMPONENT` só é aceito com **dois botões físicos pressionados simultaneamente**. É simplório e é exatamente o ponto: separa fisicamente *quem digita* de *quem autoriza*. Um operador sozinho, mesmo com acesso administrativo total ao host, não carrega componente nenhum.

Por que isso existe, além de desconfiança: um operador que **não pode** agir sozinho não pode ser coagido com sucesso individual, não pode ser subornado individualmente, e não pode cometer o erro sozinho. Remove-se a possibilidade, não a tentação.

Num HSM comercial o mecanismo é mais rico — cada custodiante se autentica com smartcard e PIN, e o log registra *quem* autorizou. Mas a estrutura é a mesma, e a versão com dois botões torna visível o que a versão com smartcards esconde atrás de conveniência.

Por que a integridade do botão é código de segurança

Um contato mecânico produz dezenas de transições elétricas em poucos milissegundos ao ser pressionado ou solto. Sem filtragem, um único toque parece vários pressionamentos.

Se o firmware ler "pressionado" num ressalto que ocorreu **depois** de o custodiante soltar o botão, ele registrou uma autorização que ninguém deu. O mecanismo de autorização precisa refletir **intenção humana**, não estado elétrico de contato — e a distância entre as duas coisas é uns 10 ms de filtro.

8. Key blocks: por que o formato é feio

TR-31 (hoje ANSI X9.143) é o formato de troca de chaves da indústria de pagamentos. Um key block é ASCII, tem cabeçalho legível, e parece desnecessariamente complicado. Cada complicação existe por causa de um incidente.

```
D0112K0AB00N0000  <corpo cifrado em AES-CBC>  <CMAC>
^^^^^^^^^^^^^^^^
cabeçalho, em claro, mas COBERTO PELO MAC
```

O cabeçalho declara o que a chave é: versão do formato, comprimento, **uso** (`K0` = KEK, `B0` = BDK, `D0` = dados), algoritmo, **modo de uso** (só cifrar, só decifrar, ambos) e **exportabilidade**.

O ataque que o formato existe para impedir

Se o cabeçalho não fosse autenticado junto com o corpo, um atacante poderia pegar um key block legítimo e:

- trocar `N` (não exportável) por `E` (exportável), e depois exportar a chave em claro por um caminho autorizado;
- trocar o uso de "só verificar PIN" para "cifrar dados arbitrários", e usar a chave de PIN como oráculo de cifra;
- trocar o algoritmo declarado, induzindo o módulo a usar a chave num modo para o qual ela não foi projetada.

A chave continuaria criptograficamente válida, o HSM a importaria sem reclamar, e ela passaria a fazer algo que o dono nunca autorizou.

Isso **não é hipotético**. É a razão histórica pela qual os formatos anteriores — os chamados *variant key blocks*, em que o tipo era codificado por XOR com um vetor de controle — foram abandonados pela indústria. Bond e Clulow mostraram famílias inteiras de ataques que consistiam em manipular esses vetores para converter uma chave de um tipo em outro.

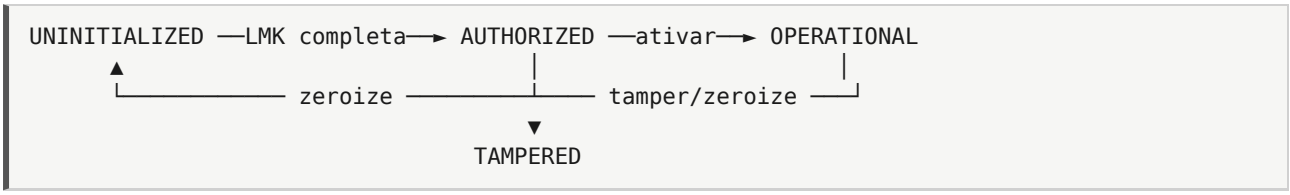
Consequência de projeto: **um byte errado no cabeçalho explode o MAC inteiro**. É o comportamento desejado, e é o que torna a implementação irritante de acertar.

Por que escrever o parser duas vezes

Neste projeto o TR-31 é implementado em C no firmware e em Python no host, e os dois validam-se mutuamente sobre blocos aleatórios.

É de longe a forma mais rápida de aprender o padrão de verdade, porque a menor divergência — um byte de preenchimento, uma ordem de campo, um comprimento incluído ou não na contagem — aparece imediatamente como MAC inválido. Não dá para "quase" implementar TR-31: ou os dois lados concordam em cada byte, ou nada funciona.

9. Máquina de estados: a chave de switch



HSMs comerciais têm uma chave física de três posições no painel. Este é o modelo.

Comandos sensíveis — carga de componente, exportação de material derivado da LMK, mudança de política — existem **apenas** em `AUTHORIZED`. E `AUTHORIZED` é um estado no qual o dispositivo **não atende produção** e no qual só se entra por ação física deliberada.

O raciocínio: em operação normal, a superfície de ataque deve ser mínima. Em `OPERATIONAL`, o dispositivo faz o trabalho e nada mais — não carrega chave, não exporta LMK, não muda política. Um invasor que comprometa **totalmente** o host de produção ainda não carrega componente de LMK, porque o dispositivo não aceita aquele opcode naquele estado, e mudar de estado exige mão humana no equipamento.

`TAMPERED` é absorvente, e **mais absorvente do que este texto dizia até a Fase 3 ser implementada**: não se sai dele por software, ponto. Nem por zeroize.

A distinção é fina e importa. O `ZEROIZE` funciona em `TAMPERED` — é exatamente ali que ele mais precisa funcionar — e apaga toda chave. Mas o estado **fica**. Apagar o que o dispositivo protegia não desfaz o veredito que ele deu sobre si mesmo; um módulo que se cura de tamper não detectou tamper nenhum, apenas registrou um incômodo.

Sair de `TAMPERED` exige energia removida e um boot em que o autoteste passe. Se a causa era física, ele não passa — que é o comportamento certo.

E um dispositivo em `TAMPERED` deve responder o mínimo possível: o estado existe para proteger o que restou, não para continuar servindo. Só dois comandos respondem ali — `SELFTEST`, para dizer **o que** reprovou, e `ZEROIZE`, para apagar.

10. Aleatoriedade: onde HSM vira ciência

Um HSM é tão bom quanto seu gerador. Chave previsível é chave pública, e o histórico de falhas nessa área é longo e caro.

A arquitetura padrão tem duas camadas:

```
fonte física  ──►  testes de saúde  ──►  DRBG  ──►  chaves
(ruído)            RCT + APT             AES-CTR
entropia bruta     SP 800-90B            SP 800-90A
```

Por que não usar a fonte física diretamente

Ruído físico tem viés e correlação. Osciladores em anel num FPGA — a fonte usada neste projeto — são sensíveis a temperatura e a tensão de alimentação. E um atacante que controle a fonte de alimentação pode **reduzir a entropia** sem que nada pareça errado do lado de fora.

O DRBG existe para transformar entropia imperfeita mas *suficiente* num fluxo computacionalmente indistinguível de aleatório. Ele não cria entropia — ele a estica e a uniformiza.

Testes de saúde: o coração da coisa

SP 800-90B exige que a fonte seja monitorada **continuamente**, não validada uma vez na fábrica. Dois testes obrigatórios:

RCT (*Repetition Count Test*) — dispara se a mesma amostra se repete acima de um limiar. Pega a falha catastrófica: o oscilador parou, a fonte travou num valor, o pino soltou.

APT (*Adaptive Proportion Test*) — janela de 512 ou 1024 amostras, dispara se um valor domina a janela. Pega a degradação: a fonte ainda oscila, mas ficou enviesada.

Falha em qualquer um → `TAMPERED`, DRBG parado, indicador vermelho. Não é paranoia: é a diferença entre "gerei uma chave fraca e não sei" e "me recusei a gerar".

Escrever esses testes ensina mais sobre certificação de módulo criptográfico que qualquer texto sobre o assunto — eles são boa parte do motivo de uma avaliação levar meses.

11. Self-test: por que o dispositivo se recusa a funcionar

FIPS 140-3 exige que o módulo rode testes de resposta conhecida (**KAT**, *Known Answer Test*) na inicialização, **antes** de aceitar qualquer comando, e que entre em estado de erro se qualquer um falhar.

Parece burocracia. Não é, e o raciocínio é bonito:

> *Um AES que cifra errado não produz erro. Produz criptograma.*

Você não descobre nada até tentar decifrar — possivelmente meses depois, possivelmente em outro dispositivo, possivelmente sobre o único backup que existia. Um bit preso numa memória, uma violação de temporização marginal que só aparece a 60 °C, uma corrupção na configuração do FPGA: todos se manifestam como criptografia silenciosamente errada.

Os KAT são o único momento em que o dispositivo consegue dizer **"eu não estou funcionando"** antes de causar dano.

Neste projeto os mesmos vetores rodam nos testbenches de simulação **e** no POST em hardware. Isso é deliberado e diagnóstico: se um KAT passa na simulação e falha no POST, o problema está no barramento ou na integração, não no núcleo criptográfico.

E há uma regra que decorre disso, adotada como inviolável neste projeto:

> ***Se um KAT falha, o bug está no código, não no vetor.*** *Não ajustar vetor, não relaxar assert, não marcar teste como ignorado.*

Um teste enfraquecido para passar é pior que teste nenhum, porque agora existe uma afirmação falsa de correção, e alguém vai confiar nela.

12. Zeroização: apagar é mais difícil do que parece

```
    memset(chave, 0, 32);   /* ...e a função termina aqui */
```

Para o compilador, isso é um *dead store*: escrita num buffer que ninguém lê depois. O padrão C **permite** eliminá-lo, e com otimização ativada o compilador elimina. A chave permanece na memória, intacta, e o código *parece* correto na revisão — inclusive para um revisor experiente.

A solução é forçar o compilador a tratar cada escrita como efeito colateral observável:

```
void wipe(void *p, size_t n)
{
    volatile uint8_t *q = (volatile uint8_t *)p;
    while (n--) *q++ = 0u;
    __asm__ __volatile__("" ::: "memory");
}
```

`volatile` impede a eliminação; a barreira de memória impede reordenamento.

Zeroização é **requisito explícito** do FIPS 140-3, e a exigência vai além de chamar a função: um módulo certificado precisa demonstrar que o material foi efetivamente destruído. Por isso, neste projeto, o comando `ZEROIZE` sobrescreve a região com padrão e depois com zeros, e o **teste faz dump da região e verifica**. "Chamei a função de apagar" não é evidência.

13. Log de auditoria: por que antes, não depois

O registro é gravado **antes** de executar o comando. Isso é contraintuitivo — parece natural registrar o resultado.

O motivo: um log escrito depois só registra sucesso. Tentativa que falhou, comando que travou o dispositivo, sequência que causou reset — nada disso aparece. E é exatamente essa a informação que importa numa investigação.

Um atacante sondando a API produz **muitos erros e poucos sucessos**. Um log de sucessos mostra um dispositivo perfeitamente saudável enquanto ele está sendo mapeado.

Requisitos que decorrem:

- **contador monotônico**, para detectar remoção de entradas;
- **gravação antes da execução**, para capturar o que travou;
- **sem material de chave**, obviamente;
- **armazenamento que sobrevive à queda de energia**, senão o ataque termina com um puxão no cabo.

14. Ciclo de vida de uma chave

Amarrando as seções anteriores: uma chave, do nascimento à morte, e onde cada mecanismo entra.

Fase	O que acontece	Mecanismo
Geração	Dentro do módulo, a partir do DRBG	Testes de saúde da fonte, POST
Atribuição	Recebe atributos: uso, modo, exportabilidade	Estrutura do slot
Distribuição	Sai embrulhada em key block, ou nunca sai	TR-31, KBEK/KBAK, `exportability`
Armazenamento	BRAM interna; backup como key block	Fronteira, hierarquia sob LMK
Uso	Só operações permitidas pelo modo de uso	Mediação, máquina de estados
Rotação	Nova chave gerada, antiga marcada	`use_count` , política
Destruição	Zeroize, com prova	`wipe()` , verificação por dump

A parte que quase sempre é subestimada é a **destruição**. Uma chave que “não é mais usada” mas continua num backup de fita, num slot que ninguém limpou, ou na memória de um módulo que foi para o lixo, continua sendo uma chave viva do ponto de vista do atacante.

Parte III — Como HSMs são atacados

Esta parte é o contrapeso da anterior. Cada mecanismo descrito até aqui existe porque alguém, em algum momento, quebrou um dispositivo que não o tinha.

Os ataques abaixo são **públicos e históricos**, documentados em literatura acadêmica e usados há décadas no ensino de segurança. Estão aqui pelo motivo de sempre: não se projeta defesa sem entender o ataque.

15. Ataques de API — o mais importante

A observação central, e a que mais custa a ser internalizada:

> *Contra um HSM bem construído, você não ataca a criptografia. Você ataca a **API** — procura uma sequência de comandos, todos legítimos, que combinados revelem algo que nenhum comando isolado revelaria.*

O módulo funciona perfeitamente. Cada chamada é válida. Nenhum algoritmo é quebrado. E ainda assim a chave sai.

Este é o tipo de ataque que mais aparece contra HSMs reais, e o menos intuitivo para quem vem de criptografia teórica — porque a falha não está na matemática, está na **composição** de operações.

15.1 Confusão de tipo de chave

Nos formatos antigos da IBM CCA, o tipo de uma chave era codificado fazendo-se XOR de um *vetor de controle* com a chave mestra antes de cifrar a chave de trabalho. O tipo, portanto, não era autenticado — era apenas um valor combinado.

Mike Bond (2001) mostrou famílias de ataques que consistiam em manipular esses vetores para **converter uma chave de um tipo em outro**. Uma chave destinada a derivar PINs podia ser reapresentada ao módulo como chave de dados; a partir daí, bastava pedir ao HSM que cifrasse com ela para obter o que deveria ser secreto.

A defesa é o TR-31, e agora a seção 8 faz sentido: o cabeçalho declara o tipo *e é coberto pelo MAC*. Alterar o tipo invalida o bloco inteiro. Toda a feiura do formato existe por causa desta classe de ataque.

15.2 Ataque da tabela de decimalização

O exemplo mais didático que existe, porque a matemática é trivial e o efeito é devastador.

O método de verificação de PIN IBM 3624 funciona assim: cifra-se o número da conta com a chave de derivação, obtêm-se dígitos hexadecimais, e uma **tabela de decimalização** os mapeia para decimais:

```
    hex:    0 1 2 3 4 5 6 7 8 9 A B C D E F
    tabela: 0 1 2 3 4 5 6 7 8 9 0 1 2 3 4 5     (padrão)
```

O problema: algumas APIs permitiam que **o chamador fornecesse a tabela**.

Bond e Zieliński (2003) observaram que, ao fornecer uma tabela degenerada — por exemplo, toda de zeros exceto uma posição — o atacante aprende, a cada consulta, se um determinado dígito aparece no PIN. Poucas consultas revelam o conjunto de dígitos; poucas mais revelam a ordem.

O resultado: recuperação de um PIN de quatro dígitos em cerca de **quinze chamadas de API**, contra as cinco mil de uma busca exaustiva. E cada chamada é perfeitamente legítima.

A lição de projeto: todo parâmetro controlado pelo chamador é uma entrada de ataque, inclusive os que parecem configuração inofensiva. É a razão do item mais importante do checklist deste projeto:

> *O que este comando pode fazer vazar se for chamado em laço com entradas escolhidas?*

Note que a pergunta não é "este comando vaza a chave?". É "**dez mil chamadas** deste comando vazam a chave?".

15.3 Ataques a PIN blocks

Um PIN não trafega sozinho: ele vai dentro de um *PIN block*, que combina o PIN com o número da conta. O formato mais comum, ISO-0 (ANSI X9.8), faz XOR entre o PIN preenchido e parte do número da conta.

HSMs de pagamento precisam **traduzir** PIN blocks — de uma chave para outra, de um formato para outro — porque a rede de pagamentos tem domínios de chave distintos entre adquirente, bandeira e emissor.

Clulow (2003) e outros mostraram que a combinação de tradução de formato com controle sobre o número da conta fornecido permite extrair informação sobre o PIN, um pedaço de cada vez. O módulo nunca revela o PIN; ele revela se uma operação teve sucesso, e isso basta.

A lição: funções de conversão são pontos de vazamento. Sempre que um módulo traduz entre representações, ele pode virar oráculo — e o mesmo padrão aparece fora de pagamentos, no *padding oracle*, em que um servidor que distingue "preenchimento inválido" de "MAC inválido" entrega decifração completa a quem perguntar o suficiente.

É por isso que, neste projeto, o arquivo de códigos de status carrega esta regra:

```
/* Um status nunca pode revelar mais do que o host tem direito de saber.
   "Chave errada" e "slot vazio" devem ser o mesmo codigo sempre que a
   distincao ajudar um atacante a enumerar o key store. */
```

15.4 O padrão comum

Repare no que os três têm em comum:

1. Todas as chamadas são **legítimas** — nenhuma validação foi burlada.
2. O vazamento vem da **composição**, não de um comando isolado.
3. O canal é estreito (um bit de sucesso/falha), e mesmo assim suficiente.
4. A defesa está no **projeto da API**, não em criptografia mais forte.

E é por isso que “todo opcode novo precisa de entrada na tabela, verificação de estado e teste, nessa ordem” é regra de projeto e não burocracia. A hora barata de perceber que um comando vaza é antes de escrevê-lo.

16. Canais laterais

Aqui o atacante não fala com a API. Ele **observa o dispositivo trabalhando** e infere o segredo a partir de algo que não era para ser saída.

16.1 Tempo

Kocher (1996) mostrou que o tempo de execução de exponenciação modular depende dos bits do expoente. Medindo tempos de resposta, recupera-se a chave privada.

A versão moderna mais comum não envolve matemática de chave pública: é **comparação de MAC que retorna cedo**.

```
    /* ERRADO: vaza o comprimento do prefixo correto */
    if (memcmp(mac_calculado, mac_recebido, 16) != 0) return ERRO;
```

`memcmp` retorna assim que encontra diferença. Um atacante mede o tempo, descobre quantos bytes iniciais acertou, e reconstrói o MAC byte a byte — 2*16*256 tentativas em vez de 2^128.

A defesa é **comparação em tempo constante**: acumular diferenças em vez de retornar cedo.

```
    uint8_t diff = 0;
    for (int i = 0; i < 16; i++) diff |= a[i] ^ b[i];
    return diff == 0;
```

16.2 Cache

Uma variação que merece destaque porque explica uma decisão deste projeto. Implementações de AES por tabela têm tempo de acesso dependente do dado: se a entrada da tabela está em cache, é rápida; se não, lenta. E o índice da tabela depende da chave.

Bernstein (2005) e Osvik–Shamir–Tromer (2006) demonstraram recuperação de chave AES a partir apenas de temporização de cache, inclusive remotamente.

É por isso que neste projeto **as caches do processador estão desligadas**. Elas seriam inúteis (a memória interna já responde em um ciclo) e nocivas (introduzem tempo dependente do dado). Duas razões independentes, ambas suficientes.

16.3 Consumo de energia

Kocher, Jaffe e Jun (1999) introduziram a análise de potência:

SPA (*Simple Power Analysis*) — observar um único traço de consumo e ler a estrutura da operação. Numa exponenciação ingênua, quadrado e multiplicação têm assinaturas diferentes, e o traço *desenha* o expoente.

DPA (*Differential Power Analysis*) — coletar milhares de traços com entradas variadas e correlacionar estatisticamente com uma hipótese sobre alguns bits da chave. A hipótese certa produz correlação; as erradas, ruído. Funciona mesmo quando o sinal é muito menor que o ruído, porque a estatística acumula.

DPA é devastadora contra implementações desprotegidas e é a razão de existir uma indústria inteira de contramedidas: **mascaramento** (dividir valores intermediários em partilhas aleatórias), **blinding** (randomizar a entrada de forma reversível), **embaralhamento** da ordem de operações, lógica de trilha dupla, e geradores de ruído.

16.4 Emissão eletromagnética

Mesmo princípio da análise de potência, mas captado por sonda próxima em vez de resistor em série. Vantagem para o atacante: é **local** — dá para posicionar a sonda sobre um bloco específico do chip e isolar o sinal que interessa, o que é especialmente eficaz contra circuitos grandes.

16.5 Onde este projeto está

Sem defesa de canal lateral **físico**, e vale ser explícito: o AES no fabric não é mascarado, não há gerador de ruído, e nada no projeto tenta igualar consumo de corrente.

O que existe são as defesas que custam pouco e valem sempre:

- **caches desligadas**, para que o padrão de acesso à memória não vire sinal;
- **uma única comparação de segredo em todo o firmware, e ela é de tempo constante.** Não é zelo espalhado — é o contrário: ter duas comparações, uma segura e uma comum, é exatamente como se escolhe a errada no caminho raro. Vale para MAC, KCV e vetores de teste igualmente, inclusive onde não há segredo nenhum a proteger;
- **um único código de erro para toda recusa de importação de key block**, pelo mesmo motivo pelo qual o oráculo de padding existe: o atacante não precisa da chave, precisa que a vítima diga em qual etapa parou.

As duas últimas são canal lateral **lógico** — vazamento por tempo e por mensagem de erro. São as que dá para fechar em firmware, e estão fechadas. O que fica aberto é o físico, e a Fase 6 do plano ataca o próprio dispositivo — é lá que o assunto vira prático.

17. Injeção de falha

Se observar não basta, **estrague o cálculo e observe o erro**. É uma das famílias de ataque mais eficientes contra hardware criptográfico.

17.1 O ataque Bellcore

O exemplo mais elegante da área. Boneh, DeMillo e Lipton (1997) mostraram que **um único erro** numa assinatura RSA feita com o Teorema Chinês do Resto revela a fatoração da chave.

O RSA-CRT calcula duas metades, uma módulo `p` e outra módulo `q`, e as combina. Se uma das metades sair errada por causa de uma falha induzida, a assinatura resultante `s` satisfaz uma congruência e não a outra. Então:

```
    gcd(s^e - m  mod N,  N)  =  p
```

Uma assinatura defeituosa, um cálculo de máximo divisor comum, e a chave privada de 2048 bits está fatorada.

Isso é imensamente relevante para a Fase 7 deste projeto, que implementa RSA-2048 por Montgomery nos DSPs. **A contramedida padrão é verificar a assinatura antes de emiti-la** — gastar uma exponenciação pública (barata, expoente pequeno) para garantir que a privada saiu certa.

17.2 Análise diferencial de falhas em cifras de bloco

Para AES, Piret e Quisquater (2003) mostraram que uma falha injetada nas últimas rodadas restringe drasticamente o espaço de chaves: poucos pares correto/defeituoso bastam para recuperar a chave de rodada, e dela a chave mestra.

17.3 Como se injeta a falha

Método	Custo	O que faz
Glitch de clock	muito baixo	Pulso curto demais faz a CPU pular ou corromper uma instrução
Glitch de tensão	baixo	Queda breve na alimentação, mesmo efeito
Pulso eletromagnético	médio	Sem contato, localizado
Laser	alto	Precisão de célula individual, exige decapsulação
Temperatura	baixo	Fora de faixa, memórias e lógica ficam instáveis

O glitch de clock é o mais didático e o mais barato. Se o pulso cair no instante certo, a CPU pula uma instrução — e se a instrução pulada for o `if` que compara o PIN, ou o que verifica a exportabilidade da chave, você contornou a verificação sem tocar em criptografia alguma.

17.4 Contramedidas

- **Dupla execução e comparação** — calcular duas vezes e confrontar. Dobra o custo e derrota falhas isoladas.
- **Verificação do resultado** — no RSA, checar a assinatura antes de emitir.
- **Sensores** — detectores de frequência fora de faixa, de tensão, de temperatura, de luz. Ao disparar: zeroize.
- **Redundância na codificação** — representar estados críticos com valores distantes em distância de Hamming, para que um bit trocado não converta “recusado” em “aceito”.

O último ponto é subestimado. Se `AUTORIZADO = 1` e `NEGADO = 0`, um único bit trocado inverte a decisão. Se `AUTORIZADO = 0x5A` e `NEGADO = 0xA5`, é preciso trocar muitos bits coordenadamente.

17.5 Onde este projeto está

O gerador de clock deste projeto tem a versão mínima e honesta de um sensor:

```
    wire rst_src_n = locked_w & rst_n_sync[1];
```

Perda de lock do MMCM **reafirma o reset** em vez de ser ignorada. Não sabemos *por que* o lock caiu, mas sabemos que não dá para confiar no que vier depois. Um HSM real iria além: zeroizaria, iria para `TAMPERED`, e registraria o evento.

A Fase 6 do plano faz exatamente este ataque contra o próprio dispositivo — glitch de clock pela porta de reconfiguração dinâmica do MMCM — e depois implementa as contramedidas. É o roteiro clássico de aprender segurança de hardware: construir, quebrar, reforçar.

18. Ataques físicos e antitamper

O degrau mais alto da escada: o atacante tem o aparelho na bancada.

18.1 A escada da resistência

Nível	Nome	O que significa
1	**Tamper-evident**	A violação deixa marca visível: lacre, resina que estilhaça, tinta que mancha
2	**Tamper-resistant**	A violação é difícil: resina dura, blindagem, parafusos especiais
3	**Tamper-responsive**	O dispositivo **detecta e reage**: malha ativa que zeroiza ao ser rompida
4	**Environmental failure protection**	Detecta condições anormais — temperatura, tensão — e zeroiza antes de falhar

O salto conceitual está entre 2 e 3. Resistência apenas ganha tempo; **resposta** destrói o alvo. Um HSM de alto nível tem uma malha de trilhas finíssimas envolvendo a eletrônica, monitorada continuamente. Furar, esmerilhar ou dissolver a resina rompe a malha, e a chave desaparece antes que se chegue nela.

18.2 Por que a bateria importa

A malha precisa estar viva mesmo com o equipamento desligado — senão o ataque é trivial: corte a energia, abra com calma. Por isso HSMs de alto nível têm bateria interna que mantém detectores e memória de chaves.

E daí decorre um comportamento que parece defeito e é projeto: **um HSM cuja bateria descarregou acorda zeroizado e inútil.** É a falha segura correta.

Este projeto reproduz isso por acidente de hardware, e o acidente é instrutivo: no core board QMTECH usado, o pino `VCCBATT` está ligado ao rail de 1,8 V, sem bateria. A chave de bitstream em BBRAM se perde a cada desligamento e precisa ser recarregada por JTAG.

Aqui isso é desejável — nada persiste no hardware, tudo é recuperável — e é exatamente o comportamento de um HSM comercial com bateria descarregada.

18.3 Ataques invasivos

- **Decapsulação** — remover o encapsulamento com ácido ou plasma, expondo o die.
- **Microssondagem** — colocar sondas em trilhas internas e ler barramentos diretamente.
- **FIB** (*Focused Ion Beam*) — cortar e refazer ligações no próprio die; permite, por exemplo, desconectar um sensor.
- **Imageamento** — ler ROM ou fusíveis opticamente, ou por microscopia eletrônica.
- **Cold boot** — resfriar a memória para retardar a perda de conteúdo e lê-la em outro equipamento. Relevante para DRAM, e mais um motivo para chaves não morarem em memória externa.

18.4 O que este projeto não tem

Absolutamente nada disso. Não há resina, malha, sensor, bateria ou blindagem. O FPGA está numa placa de desenvolvimento com conectores de expansão expostos.

Vale registrar sem rodeios: **o modelo de ameaça deste projeto vai até o adversário que fala com a API.** Contra qualquer coisa acima disso, ele não oferece defesa — e não pretende.

O valor está em entender por que os degraus existem. Um leitor que termine esta parte sabendo *o que* uma malha ativa faz, *por que* ela precisa de bateria e *por que* um HSM sem bateria acorda inútil aprendeu algo que nenhum diagrama de blocos ensina.

Parte IV — Certificação

Um HSM comercial não é vendido pelo que faz, e sim pelo que **um terceiro verificou** que ele faz. Esta parte explica o que os selos significam — e, igualmente importante, o que não significam.

19. FIPS 140-3

A norma dos Estados Unidos para módulos criptográficos, hoje alinhada à ISO/IEC 19790. Substituiu a FIPS 140-2, e a validação é feita pelo CMVP (programa conjunto NIST/CCCS) por meio de laboratórios credenciados.

A norma define **quatro níveis**, e a diferença entre eles é quase toda física.

Nível 1

Requisitos mínimos. Algoritmos aprovados, implementados corretamente. **Sem exigência de segurança física** — uma biblioteca de software rodando num PC comum pode ser validada em nível 1.

Utilidade real: garante que o AES é AES de verdade e que os testes de resposta conhecida existem. Não diz nada sobre proteger a chave de quem tem acesso à máquina.

Nível 2

Acrescenta **evidência de violação**: lacres, revestimentos ou invólucros que mostrem que alguém abriu. E autenticação **por papel** — o módulo distingue "operador" de "administrador".

A palavra-chave é *evidência*: o nível 2 não impede a violação, garante que ela deixe marca.

Nível 3

Aqui a coisa fica séria. Acrescenta:

- **Resistência e resposta à violação** — o módulo detecta a intrusão e **zeroiza** os parâmetros críticos de segurança;
- **autenticação por identidade** — não basta o papel, é preciso saber quem;
- **separação física ou lógica** das interfaces por onde entram e saem parâmetros críticos.

A maior parte dos HSMs comerciais de propósito geral é validada em nível 3.

Nível 4

O topo. Um **envelope completo de proteção**: qualquer tentativa de acesso físico, de qualquer direção, é detectada e responde com zeroização. E acrescenta **proteção contra falhas ambientais** — o módulo detecta tensão ou temperatura fora da faixa e zeroiza antes que a condição possa ser explorada.

O nível 4 é caro, e existem poucos produtos. É a resposta direta aos ataques descritos na seção 17: se você pode congelar o chip ou baixar a tensão para induzir falhas, o módulo precisa perceber e se destruir primeiro.

O vocabulário que a norma impõe

Vale conhecer, porque aparece em toda documentação da área:

- **CSP** (*Critical Security Parameter*) — chave em claro, dado de autenticação, qualquer coisa cuja divulgação comprometa a segurança.
- **Estado de erro** — condição em que o módulo entra ao falhar um autoteste e na qual **não realiza operações criptográficas**.
- **Modo aprovado** — o conjunto de operações e algoritmos cobertos pela validação. Um módulo pode ter funções fora do modo aprovado; usá-las tira você da conformidade.
- **Autotestes** — os KAT da seção 11, exigidos na inicialização e sob condições específicas.

20. PCI: as regras de pagamentos

Enquanto FIPS avalia o **módulo**, o mundo de pagamentos regula também **como ele é operado**.

PCI PTS HSM define requisitos de segurança para o equipamento usado em processamento de PIN e chaves de pagamento.

PCI PIN Security Requirements cobre a operação: como chaves são geradas, transportadas, carregadas, trocadas e destruídas. É daqui que vêm, como exigência contratual e não como boa prática:

- **dual control** — nenhuma operação sensível de chave por uma pessoa só;
- **split knowledge** — nenhuma pessoa conhece uma chave inteira;
- **cerimônia documentada**, com testemunhas e registro;
- **key blocks** para transporte de chave — e há prazos de migração obrigatória para formatos como o TR-31.

É por isso que este projeto modela LMK, componentes e dual control com botões físicos: no mundo de pagamentos esses mecanismos são **requisito auditado**, não escolha de arquitetura.

21. Common Criteria

Norma internacional (ISO/IEC 15408) com abordagem diferente: em vez de níveis fixos, define **perfis de proteção** — descrições do que um tipo de produto deve fazer — e avalia produtos contra eles, com um nível de garantia (**EAL 1 a 7**) que indica o rigor da avaliação, não a força da segurança.

Confusão comum, e vale desfazer: **EAL alto não significa "mais seguro"**. Significa "avaliado com mais rigor e mais documentação formal". Um produto simples avaliado em EAL 6 pode proteger menos que um produto rico em EAL 4 — o que o EAL mede é a confiança na avaliação, não a altura do muro.

Na Europa, perfis como o EN 419221-5 cobrem módulos criptográficos para serviços de confiança, e são o caminho para dispositivos de assinatura qualificada sob o eIDAS.

22. O que “certificado” significa — e o que não significa

Esta seção é a mais importante da Parte IV.

Significa

- Um laboratório independente verificou as afirmações do fabricante.
- Os algoritmos foram testados contra vetores oficiais.
- Existe documentação de fronteira, de estados, de papéis e de zeroização.
- Há um processo de reavaliação quando o produto muda.

Não significa

Não significa “inviolável”. Certificação estabelece um piso verificado, não um teto. Módulos certificados já foram quebrados — e certificados são revogados ou emendados quando isso acontece.

Não significa que a sua configuração está segura. A validação cobre o módulo operando em **modo aprovado**, numa configuração específica descrita na política de segurança. Usá-lo fora dali é usar um produto não validado com um adesivo de validado.

Não significa que o sistema em volta está seguro. O HSM protege a chave. Se a aplicação assina qualquer coisa que peçam, o atacante não precisa da chave — ele pede a assinatura. Essa é, na prática, a falha mais comum em implantações reais: um HSM impecável atrás de uma API de aplicação que autoriza demais.

Não significa nada sobre canal lateral, salvo se explicitado. Resistência a DPA é avaliada separadamente e nem sempre está incluída.

A moral para este projeto

Não há nenhuma pretensão de certificação aqui, e nem poderia haver. Mas conhecer a estrutura das normas explica **por que** as fases do plano estão na ordem em que estão:

- os autotestes da Fase 2 são o requisito de autoteste do FIPS;
- a máquina de estados da Fase 3 é a separação de papéis;
- o zeroize com prova é o requisito de zeroização;
- o log de auditoria é a evidência;
- os sensores da Fase 6 são o nível 3/4 de resposta física.

Implementar cada mecanismo e depois ler o parágrafo da norma que o exige é uma forma muito eficiente de entender a norma — e de perceber que ela não é burocracia arbitrária, mas cicatriz acumulada.

Parte V — O projeto hsm-a7

23. Objetivo, plataforma e restrições

O objetivo

Construir, do zero, um módulo criptográfico com hierarquia de chaves, cerimônia de carga, key blocks e API de host — reproduzindo a arquitetura de um HSM real em escala reduzida, para **entendê-la de dentro para fora**.

A escolha de fazer em FPGA, e não em software, é deliberada: obriga a enfrentar a fronteira física, a distinguir memória interna de externa, e a lidar com clock e reset como questões de segurança e não de infraestrutura.

A plataforma

Item	Valor
FPGA	Xilinx Artix-7 **XC7A35T**, encapsulamento FTG256, speed grade -1
Placa	QMTECH core board + daughterboard
Recursos	20.800 LUTs, 41.600 flip-flops, 50 BRAMs, 90 DSP48E1
Clock	50 MHz no pino N11 → 100 MHz por MMCM
Processador	NEORV32 (RISC-V RV32IMC), submódulo fixado em v1.13.3
Canal	UART 115200 8N1 pelo CP2102 do core board
Flash	MT25QL128, 16 MB, a mesma que guarda o bitstream

O orçamento de fabric é apertado de propósito: AES, SHA, key store e processador precisam caber em 20.800 LUTs, e isso força decisões explícitas em vez de acumulação.

As restrições invioláveis

Estas não são preferências. Estão no topo do plano e do arquivo de instruções do projeto.

1. Nada de eFUSE. Não gerar, sugerir ou executar `program_efuse`, `CFG_AES_ONLY`, `W_DIS` / `R_DIS` ou qualquer variante. São memórias de programação única: o erro é um *brick* permanente. Chave de bitstream apenas em BBRAM, que é recuperável.

2. Chaves em claro só em BRAM. Nunca DDR3, nunca flash sem embrulho, nunca um registrador exposto no toplevel.

3. Nada atravessa a fronteira em claro. Saem apenas key blocks embrulhados, KCVs, criptogramas, *handles* e log.

4. Simulação antes de hardware. Nenhum módulo vai para a placa sem testbench passando. Depurar criptografia por UART, sem visibilidade interna, é a forma mais lenta possível de descobrir que faltou um byte no preenchimento.

5. Não enfraquecer testes para fazer algo passar. Se um KAT falha, o bug está no código, não no vetor.

A regra do eFUSE merece um comentário, porque ela ilustra um princípio geral: **preferir sempre o mecanismo recuperável ao irreversível, num projeto de estudo**. O JTAG também nunca é desabilitado — é a única via de recuperação, e um projeto de aprendizado precisa poder voltar atrás. Um produto real faria o oposto em ambos os casos, e entender por que os dois caminhos são corretos em contextos diferentes é parte do conteúdo.

24. Fase 1, peça por peça

Esta seção pega cada arquivo escrito e responde: **o que essa peça corresponde num HSM real?**

Cada uma termina com *o que ainda falta*, porque a distância entre o brinquedo e o produto é o conteúdo das fases seguintes.

Mapa

O que construímos	O que é num HSM real
`clk_rst_gen.v`	Monitor de integridade do clock (sensor antitamper)
`debounce.v`	Integridade da autorização física (dual control)
`neorv32_wrapper.vhd`	Endurecimento da plataforma: o que a máquina **não** faz
`hsm_top.v`	Definição física da fronteira criptográfica
`cmd.c`	A API — a superfície de ataque principal
CRC32	Integridade de transporte (num HSM real, viraria MAC)
`state.c`	A chave de switch de três posições
`wipe.c`	Requisito de zeroização do FIPS 140-3
LEDs D1–D5	Indicadores de estado e de violação
`BOOT_MODE_SELECT=2`	Autenticidade de firmware / secure boot
IMEM como ROM	Integridade do código em execução
`tb_soc_silent`	Higiene de canal lateral
`hsmtool.py`	O cliente da API — futuro PKCS#11
Teste de 10.000 pings	Requisito de confiabilidade operacional

24.1 `clk_rst_gen.v` — o clock é um sensor

MMCM que transforma 50 MHz em 100 MHz (VCO em 1000 MHz, meio da faixa do speed grade -1), mais geração de reset: afirma assíncrono, libera síncrono, segura 64 ciclos após o lock.

Num HSM real: monitoramento de clock é sensor antitamper. Ver seção 17.3 — glitch de clock é o ataque de injeção de falha mais barato que existe, e faz a CPU pular exatamente a instrução que verifica alguma coisa.

O ponto de projeto está numa linha:

```
    wire rst_src_n = locked_w & rst_n_sync[1];
```

Perda de `LOCKED` **reafirma o reset**. Não sabemos por que o lock caiu, mas sabemos que não dá para confiar no que vier depois.

O gerador é também a única exceção à convenção de reset síncrono do projeto, e por necessidade: com o MMCM em reset, o clock de saída não está correndo e não existe borda para registrar nada. Usa o padrão clássico *afirma assíncrono / libera síncrono*, justamente para que todo o resto do projeto possa usar reset puramente síncrono.

Falta: zeroizar e ir para `TAMPERED`, registrar o evento, e monitorar a frequência ativamente em vez de só reagir à perda de lock. Fase 6.

24.2 `debounce.v` — quando um ressalto vira autorização

Exige 10 ms de estabilidade contínua antes de aceitar mudança; qualquer transição no meio zera a contagem.

Num HSM real: integridade da autorização física (seção 7). O mecanismo precisa refletir intenção humana, não estado elétrico de contato.

Os dois botões escolhidos são o **2º e o 5º** de uma fileira de cinco, cujo primeiro é o reset — o par mais afastado disponível, o que dificulta pressionar ambos com uma mão só. Mapeamento elétrico e posição física foram os dois medidos, em datas diferentes: `SW2` → `M6` e `SW5` → `P6` em 2026-08-21, com um padrão codificado de pressões; a fileira ser mesmo `SW1` … `SW5`, por conferência visual, em 2026-08-26 (`doc/pinout.md`).

Vale a pena separar as duas medidas, porque a distinção é fácil de perder: saber em que **pino** um botão está não diz **onde ele fica na placa**, e é a posição que o operador usa. Software nenhum detecta a troca.

A camada de política acima deste filtro existe e está na seção 28: os dois botões autorizam a cerimônia de carga da chave mestra, e não basta que estejam pressionados — cada autorização exige um aperto *novo*. O `debounce` garante que o contato parou quieto; a política garante que o operador soltou.

Falta: autenticação de custodiante (smartcard + PIN) e registro de *quem* autorizou, não só de que houve autorização. Dois botões na mesma placa cabem nas duas mãos de uma pessoa — isto prova presença física, não consentimento de duas pessoas.

24.3 `neorv32_wrapper.vhd` — segurança é o que se desliga

Fixa os ~130 generics do processador. É o único lugar onde a configuração do SoC está escrita — e num relatório de avaliação, é exatamente essa lista que o laboratório examina.

Desligado	Por quê
`OCD_EN`	Debugger dá leitura e escrita irrestritas de memória por JTAG. Com a LMK em BRAM, **é** extração de chave sem passar pela API. O generic mais importante do arquivo.
`ICACHE` / `DCACHE`	Inúteis (BRAM já responde em 1 ciclo) e nocivas: tempo dependente do dado é canal lateral (seção 16.2).
`XBUS` / `SMC`	Sem barramento externo, não há caminho físico até a DDR3. A regra vira estrutura.
`IO_TRACER`	Buffer de rastreamento de execução é observabilidade indesejada.
`Zkne` / `Zknd` / `Zknh`	AES e SHA vão para o fabric via CFS: construí-los é o objetivo do projeto.

Sobre desligar o debugger, note a assimetria com a regra de nunca desabilitar JTAG no FPGA: lá é o caminho de recuperação do **bitstream**, e precisa existir num projeto de estudo. Aqui é o caminho de leitura da **memória do processador**, e não precisa. Duas coisas diferentes com o mesmo nome.

Ligados: RV32IMC (`RISCV_ISA_C` + `_M`), contadores base, barrel shifter (código criptográfico é pesado em deslocamento), IMEM 16 KB, DMEM 8 KB, UART0 com FIFO de 64, temporizador, GPIO de 8 bits.

Falta: PMP (proteção de memória física) para separar privilégio dentro do firmware, de modo que um bug no parser não alcance a região da LMK. Fase 3.

24.4 `hsm_top.v` — onde a fronteira fica física

Único arquivo do projeto que conhece nome de pino. Corresponde à **definição da fronteira criptográfica** — o desenho que num documento FIPS marca dentro e fora, com a lista de todas as portas.

Aqui a lista é curta e verificável:

Porta	Direção	O que atravessa
`uart_rxd_i` / `uart_txd_o`	ambas	comandos e respostas
`btn_a_i` / `btn_b_i`	entra	autorização física
`led_o` , `seg_o` , `seg_an_o`	sai	estado

E só. Não existe porta de dados além da UART, e o que passa por ela é definido pela tabela de comandos.

O toplevel também absorve, num ponto só, as duas inversões da placa — LEDs e botões são ativos em nível baixo. Parece cosmético e não é: **um LED de `TAMPERED` invertido é defeito de segurança**, porque o dispositivo mostraria “tudo bem” exatamente quando não está.

24.5 `cmd.c` — o parser é a superfície de ataque

Máquina de estados de recepção, verificação de CRC, tabela de comandos com verificação de estado, montagem da resposta.

Num HSM real: esta é a API, e é onde mora a maior parte dos ataques reais (seção 15).

Por isso o checklist obrigatório para todo opcode novo:

- Em quais estados é permitido?
- Exige dual control?
- **O que pode vazar se for chamado em laço com entradas escolhidas?**
- Respeita a exportabilidade do slot?
- Entra no log **antes** da execução?

O parser é deliberadamente burro: máquina de estados explícita, todos os limites verificados, sem alocação dinâmica, sem recursão. É o único código que processa entrada arbitrária antes de qualquer verificação — não é lugar para esperteza.

O timeout entre bytes é o que satisfaz o critério "frame malformado nunca trava a máquina de estados". Sem ele, um host que morre no meio de um frame deixa o parser esperando para sempre e o dispositivo mudo: negação de serviço com um único byte enviado. É rearmado a cada byte, e não por frame, porque um key block TR-31 leva cerca de 45 ms a 115200 baud e um timeout de frame teria de ser afrouxado até deixar de proteger.

Disponibilidade é requisito num HSM: um módulo que para de responder derruba a autorização de transações.

Falta: o log antes da execução (o ponto está marcado no código), e tempo de resposta constante — hoje um comando recusado responde mais rápido que um aceito, e isso é informação.

24.6 O CRC32, e por que num HSM real seria um MAC

Detecta corrupção de enquadramento. Polinômio IEEE 802.3 refletido, idêntico ao `zlib.crc32`.

Distinção que vale internalizar: CRC é detecção de erro, **não** autenticação. Quem altera o payload recalcula o CRC trivialmente.

Num HSM de pagamentos, o canal com o host costuma ser autenticado de verdade — MAC sobre a mensagem com chave de sessão, ou TLS mútuo.

Aqui o CRC basta, e o motivo é conceitualmente importante: **a fronteira de confiança está no dispositivo, não no canal**. Assumimos que o host pode ser hostil, e um host hostil não precisa falsificar CRC — ele manda comandos válidos. A defesa não é autenticar o canal; é a máquina de estados, o dual control físico e os atributos de chave.

É por isso que dual control é feito com botões na própria placa e não com um comando "eu autorizo" vindo pelo cabo.

Duas decisões de formato que o plano deixava em aberto e precisavam ser fixadas antes de o host existir:

- **o CRC cobre `LEN` + corpo** — incluir o `LEN` importa, porque é o campo que um atacante usaria para induzir leitura fora do buffer;
- **polinômio idêntico ao `zlib.crc32`** — mantém o host trivial e elimina uma fonte clássica de divergência.

O CRC existe em três implementações independentes: C no firmware, Verilog no testbench, Python no host. Divergência apareceria como erro de CRC intermitente — dos sintomas mais enganosos que existem, porque parece problema de cabo.

24.7 `state.c` — a chave de switch

Na Fase 1 este arquivo era só o enum e a consulta: o dispositivo nascia e permanecia em `UNINITIALIZED`. Existia assim, com um estado só, porque **a tabela de comandos já carregava a máscara de estados permitidos** desde o começo — retroajustar verificação de estado em cada handler depois é como se esquece um.

```
#define ST_NORMAL  (ST_UNINIT | ST_AUTH | ST_OPER)
```

`TAMPERED` fica fora de propósito: dispositivo comprometido responde o mínimo possível. A única exceção é o `SELFTEST`, e ela é deliberada — sem ela o operador teria um LED vermelho e nenhuma informação sobre o quê reprovou.

A aposta se pagou na Fase 3, e vale registrar porque é raro uma decisão de infraestrutura cobrar tão pouco depois. Quando a cerimônia de carga da chave mestra chegou (seção 28), a máquina de estados ganhou transições reais — `UNINITIALIZED` → `AUTHORIZED` → `OPERATIONAL` — e **nenhum handler existente precisou de uma linha nova**. Os comandos da Fase 2 que aceitam chave em claro no payload têm máscara `ST_UNINIT`; no instante em que existe uma chave mestra, eles param de responder sozinhos. Não há código desligando nada: a tabela simplesmente não os permite mais.

É a diferença entre política declarada e política executada. Um `if` dentro de cada handler seria a mesma regra escrita dezessete vezes — e dezessete é exatamente o número de lugares onde alguém esquece uma.

(Eram treze quando este parágrafo foi escrito. O número subir sozinho, sem que nenhuma verificação precisasse ser reescrita, é a própria demonstração do argumento.)

24.8 `wipe.c` — zeroização antes de haver chave

Ponteiro `volatile` mais barreira de memória, pelo motivo explicado na seção 12.

Está no lugar mesmo a Fase 1 não movimentando chave nenhuma, e os buffers de frame são limpos após cada comando. Motivo: são **esses mesmos buffers** que vão carregar componente de LMK e key block na Fase 3.

O hábito se pagou, e vale registrar como: quando o `ZEROIZE` chegou (seção 28), ele não precisou de uma zeroização nova — precisou de uma *segunda passada*. `wipe_padrao()` escreve um padrão antes dos zeros, e a razão não é a que o folclore de disco magnético sugere: para memória estática a passada de zeros é a que conta. A primeira existe porque uma zeroização **interrompida** tem de deixar padrão, não meia chave.

E a prova de que apagou não veio de um dump, como este texto previa. Veio de duas verificações independentes, e a segunda é a interessante — o KCV. Seção 28.

24.9 Os LEDs, e por que D1 é em hardware

D1 pisca a 1 Hz por lógica no fabric; D2 a D5 são GPIO controlado pelo firmware.

A decisão interessante: **D1 é independente da CPU**. Se o firmware travar, D1 continua piscando. Isso distingue duas falhas que de fora parecem iguais:

Sintoma	Diagnóstico
D1 parado	clock morto — MMCM sem lock, alimentação, bitstream
D1 piscando, D2 apagado	clock bom, firmware pendurado
D1 piscando, D2 aceso	plataforma viva; o problema é protocolo ou host

Num dispositivo sem console, essa é a diferença entre depurar e adivinhar. É o mesmo princípio do watchdog independente: o indicador de vida não pode depender da coisa cuja vida ele indica.

Bônus de verificação: D1 a 1 Hz cronometrado a olho **confirma a divisão do MMCM**, porque o contador é `CLK_HZ/2` e só bate 1 Hz se o clock for mesmo 100 MHz.

24.10 `BOOT_MODE_SELECT = 2` — autenticidade de firmware

O SoC sobe a partir de uma imagem embutida na IMEM, não do bootloader do NEORV32.

Num HSM real: isto é *secure boot*, um dos requisitos mais duros de certificação.

O bootloader do NEORV32 aceita upload de firmware pela UART. Com ele ligado, qualquer um com acesso ao serial substitui o firmware — e firmware substituído contorna a máquina de estados, o dual control, a exportabilidade e a fronteira inteira. **Todas as defesas discutidas neste documento passam a valer zero**, porque quem escreve o código escreve as regras.

Num HSM comercial isso se resolve com boot ROM imutável que verifica assinatura da imagem antes de executá-la, com a chave pública em memória de programação única.

A versão deste projeto é mais simples e mais rude: **não há caminho de atualização**. O firmware está no bitstream; trocá-lo exige regerar o bitstream e gravar por JTAG, o que é acesso físico.

Efeito colateral que veio de graça: com esse modo, o NEORV32 liga `MEM_INIT` e a IMEM vira memória **somente de leitura**. A memória de código não é gravável em tempo de execução — não há injeção de código nem código automodificável, independentemente de qualquer bug no parser.

Isso é integridade de código em execução. Num sistema com MMU seria o equivalente a marcar as páginas de texto como não-graváveis; aqui é mais forte, porque não é uma permissão que alguém pode mudar — é a ausência de circuito de escrita.

Também sumiu a boot ROM: a BRAM caiu de 8 tiles para 3,5.

24.11 `tb_soc_silent` — não falar sem ser perguntado

Verifica que o dispositivo não transmite nada pela UART até receber um comando — **e** que está vivo.

Num HSM real: higiene de canal lateral e de vazamento de identidade. Um banner de boot entrega versão e identidade a quem só escuta o barramento, o que é reconhecimento gratuito. E um `printf` de depuração esquecido no firmware é um canal lateral permanente, historicamente uma das formas mais comuns de vazamento em dispositivos embarcados.

O detalhe que torna o teste honesto: silêncio sozinho não prova nada, porque firmware travado também fica quieto. Por isso o teste exige silêncio **e** vida — `main()` precisa ter chegado ao laço e aceso o LED de atividade. Um teste que passa quando o dispositivo está morto é pior que teste nenhum.

24.12 `hsmtool.py` — o cliente da API

Codec do protocolo, transporte serial, CLI. Em produção isso seria PKCS#11 ou um command set ASCII de HSM de pagamento — é o que a Fase 5 constrói.

O comentário no topo do arquivo é a regra que o mantém honesto:

```
# FRONTEIRA: tudo aqui esta FORA. Este programa nunca ve chave em claro --
# so key blocks wrapped, KCVs, criptogramas, handles e log. Se algum comando
# futuro fizer material de chave aparecer neste arquivo, o comando esta
# errado, nao o script.
```

Aqui se entende por que a API de um HSM é do jeito que é: **é você que precisa impedi-la de vazar.** Quando se escreve os dois lados, a tentação de adicionar um "só para depurar, me devolva a chave" fica concreta — e recusá-la ensina mais do que ler que não se deve.

24.13 O teste de 10.000 pings

Num HSM real: disponibilidade e determinismo são requisitos operacionais. Um módulo autorizando transações tem acordo de nível de serviço; um que perde uma mensagem em dez mil produz falhas intermitentes que ninguém reproduz.

E há um aspecto de segurança: **erro intermitente esconde ataque**. Se o canal normalmente perde alguns frames, ninguém investiga o dia em que alguém está injetando tráfego. Uma taxa de erro de exatamente zero é o que torna qualquer erro digno de investigação.

25. Resultados medidos

Recursos e temporização

Recurso	Só clock/reset	Com o SoC	Com firmware	Disponível
Slice LUTs	24	2247	**2240** (10,8%)	20800
Flip-flops	42	1633	**1633** (3,9%)	41600
Block RAM	0	8	**3,5** (7%)	50
DSP48E1	0	0	**0**	90
MMCM	1	1	1	5

Temporização final: **WNS +0,637 ns** em período de 10 ns, sem endpoints falhando em 4529. Fmax ≈ 107 MHz para os 100 MHz exigidos.

A margem já caiu duas vezes — de +5,95 ns com só o gerador de clock, para +0,898 com o SoC, para +0,637 com o firmware. O caminho crítico está dentro da CPU: banco de registradores em BRAM, onze níveis de lógica com sete cadeias de carry, de volta ao banco. Os cores de criptografia da Fase 2 são datapath separado e não alongam *esse* caminho, mas adicionam congestionamento — e roteamento já é 45% do atraso.

> ***Nota escrita depois, e vale mais que a previsão.*** *O parágrafo acima acertou o mecanismo e errou a conclusão. Os cores realmente não alongaram o caminho da CPU — ele continua passando. Mas trouxeram um caminho* ***próprio****, muito pior: −2,388 ns dentro do SHA-256, contra os +0,637 ns que se estava vigiando. A margem que importava não era a que estava sendo medida.*
>
> *A lição é sobre a forma do erro, não sobre o número: vigiar a métrica que se conhece é conforto, e o que quebra costuma vir de onde ainda não há métrica. A história completa está na seção 27.*

Firmware: **1652 bytes de código, 1572 de dados não inicializados** — 10% da IMEM e 19% da DMEM. A maior parte da bss são os três buffers de frame.

Critério de aceitação, medido na placa

```
iteracoes  : 10000 em 44,3 s (226/s)
erros      : 0
latencia   : min 3,97   mediana 4,36   p99 4,85   max 6,50 ms
```

Zero erros de CRC em dez mil iterações, e o pior caso 7,7 vezes abaixo do limite de 50 ms. A distribuição é apertada, sem cauda longa — cauda longa indicaria contenção ou retentativa escondida.

A latência é dominada pelo USB, não pelo dispositivo: dezesseis bytes a 115200 baud são 1,4 ms de tempo de linha, e o resto é o temporizador de latência do CP2102. Vale lembrar disso antes de "otimizar" o firmware por engano.

26. Três lições que a Fase 1 ensinou fazendo

Não estavam no plano. Vieram de erros reais.

Verificação encontra o que revisão não encontra

O testbench do toplevel reprovou a primeira versão com `led=1111x`. Registradores sem valor inicial mais reset síncrono deixam uma janela indefinida entre a configuração do FPGA e o primeiro clock.

Em hardware a ferramenta teria inicializado implicitamente e nada apareceria. Mas a saída em questão é um **indicador visível de estado** — e na Fase 3 uma delas é o LED de `TAMPERED`. Depender de comportamento implícito da ferramenta para o estado de um indicador de segurança é exatamente o tipo de coisa que um avaliador pergunta.

Cuidado ao “corrigir” um teste que falha

O testbench de boot reprovou esperando `\n` e recebendo `\r\n`. A tentação é ajustar a expectativa e seguir.

A conduta correta foi ir verificar na fonte do NEORV32 que o driver realmente expande LF em CRLF **antes** de mexer no teste. A diferença entre “corrigi uma expectativa errada” e “ajustei o teste ao resultado observado” é invisível no diff e enorme na prática — é a mesma disciplina da regra inviolável número 5.

E há o caso inverso, que delimita a regra. O testbench do toplevel conferia que o display de 7 segmentos estava apagado com as linhas de dígito em `111`. Passou meses verde. O valor vinha de um parâmetro no código que nunca fora medido — um **palpite**, e o palpite estava invertido: o dígito habilita com `1`, então desabilitado é `000`.

Corrigir o valor esperado, nesse caso, **não** é enfraquecer o teste. O teste conferia contra uma *suposição*; a suposição foi refutada por experimento, e o valor esperado passou a ter procedência. A regra proíbe ajustar o vetor para o código passar — não proíbe trocar palpite por medida.

O critério prático que separa os dois casos: pergunte de onde veio o valor esperado. Se veio de uma norma, de um vetor oficial ou de uma medida, ele manda no código. Se veio de alguém supondo, o código e o teste estão supondo juntos — e um teste que afirma a mesma suposição do código não testa coisa alguma.

Hardware expõe o que simulação estruturalmente não pode

A ferramenta de host escolhia a primeira porta serial encontrada. Na bancada isso é o **adaptador JTAG**, porque o gravador usado é um FT232H que também cria porta serial e enumera antes da placa.

O sintoma seria timeout sem explicação, apontando para o firmware quando o problema é o cabo. Nenhum teste sem hardware pegaria: o pseudo-terminal usado no teste de transporte não tem identificador USB, e o selftest do codec nem abre porta.

A lição não é “simulação é insuficiente” — a Fase 1 pegou dois defeitos reais em simulação e só um escapou. É saber **qual classe** de defeito cada método alcança, e não confundir “os testes passam” com “está correto”.

Parte VI — O caminho adiante

27. Fase 2 — engines e self-test *(concluída)*

Objetivo: primitivas corretas e verificáveis. Correção antes de desempenho.

Bloco	Fonte	Estado
AES-256	secworks/aes	**no CFS, verificado**
SHA-256	secworks/sha256	**no CFS, verificado**
`DNA_PORT`	primitiva Xilinx	**no CFS, verificado**
TRNG	neoTRNG (do NEORV32)	**no CFS, com health tests em RTL**
CTR_DRBG	firmware	**implementado, no POST**

O que já está feito

Os vetores KAT foram baixados das fontes oficiais — NIST CAVP para AES e SHA, RFC 4231 para HMAC, SP 800-90A para o DRBG — com URL e hash SHA-256 de cada arquivo registrados num manifesto. Nada foi escrito de memória.

Isso não é formalidade. A regra inviolável do projeto diz que, se um KAT falha, o bug está no código e não no vetor — e essa regra só tem força se a procedência do vetor for verificável por um terceiro. Um script rebaixa, confere hash e reextrai; sobre um repositório limpo, o resultado é byte a byte idêntico.

Os dois cores passam:

```
AES-256   405 vetores × 4 (ECB/CBC, cifra/decifra) = 1620
SHA-256   65 mensagens, 74 blocos
```

O AESAVS traz quatro tipos de vetor e todos foram usados, porque cada um pega uma classe diferente de defeito: `VarKey` varre cada bit da chave isoladamente e acha indexação errada na expansão; `VarTxt` varre cada bit do bloco e acha ordem de byte e permutação trocadas. Um core que passa apenas no `GFSbox` pode estar inteiro errado.

Uma divisão de responsabilidade ficou registrada e vai importar no firmware: o core de AES faz ECB, e o encadeamento de CBC é de quem chama; o core de SHA recebe blocos de 512 bits já preenchidos, e o *padding* também é de quem chama. Testar o core com essas coisas embutidas misturaria falhas de naturezas diferentes.

> ***O teste encontrou um defeito no próprio teste.*** *O testbench de SHA reprovou com um sintoma característico: digests corretos, porém deslocados de um — a mensagem 1 devolvia o resultado da 0. Esperar apenas o sinal de "pronto" logo após o comando termina de imediato, porque o núcleo ainda não o baixou, e lê-se o resultado anterior. O testbench de AES passava com o mesmo handshake fraco, por sorte de temporização; recebeu a mesma correção. Teste que passa por sorte é dívida, não aprovação.*

O coprocessador: o CFS

Os cores entraram pelo **CFS** (*Custom Functions Subsystem*) do NEORV32 — um slot de periférico projetado para receber coprocessadores. O arquivo do upstream é um template feito para ser jogado fora; a substituição é feita trocando qual arquivo o build compila, sem patch e sem tocar no submódulo.

É também por onde o `GET_DNA` finalmente se resolveu, fechando a última sobra da Fase 1.

O CFS, e não um barramento externo, por um motivo de arquitetura: o coprocessador precisa estar **dentro da fronteira criptográfica** (seção 5), não pendurado num barramento que sai do die. Coerente com `XBUS_EN => false`, que é a mesma decisão vista do outro lado.

Três escolhas do mapa de registradores merecem nota, porque cada uma é um conceito da Parte II virando linha de RTL:

- **O único fio do CFS que chega ao toplevel está amarrado em zero.** Não existe caminho físico do bloco que guarda a chave até um pino. A fronteira deixa de ser promessa de firmware e vira topologia.
- **Chave e blocos de entrada são escrita-somente**; ler devolve zero. Não protege contra a CPU, que acabou de escrever a chave — evita criar um caminho de leitura que um bug use por acidente.
- **Não há AES-128.** O tamanho de chave é fixo no hardware. Um modo mais fraco alcançável por escrita em registrador seria um *downgrade* de graça, e a seção 15 mostra o que APIs fazem com modos mais fracos disponíveis.

E há um `WIPE` que não é decorativo: ele sobrescreve a **chave expandida** dentro do core, não só o registrador visível. O teste correspondente é o que separa zeroização de teatro de zeroização — depois do wipe, cifrar sem carregar chave nenhuma tem de produzir o resultado sob a chave zero.

> ***Um testbench a mais, para uma pergunta diferente.*** *Os KAT de core provam que o AES está certo. Não provam que o caminho entre a CPU e o AES está certo — um core correto atrás de um mapa de registradores com a ordem das palavras invertida produz resultados perfeitamente errados. Por isso os mesmos vetores do NIST são replicados uma segunda vez, agora* ***através do barramento****. Foi assim que a Fase 1 já tinha aprendido a separar "o módulo funciona" de "o sistema funciona".*

O preço em silício, e o que ele ensinou

Colocar criptografia no fabric custou caro e o custo apareceu onde não se esperava.

	Fase 1	Com o CFS
Slice LUTs	2240 (10,8%)	**7035 (33,8%)**
Flip-flops	1633 (3,9%)	6235 (15,0%)
Block RAM	3,5	3,5
DSP48E1	0	0

Área não foi problema — sobra um terço do chip. **Temporização foi.** O projeto vinha com +0,637 ns de folga e, com os cores dentro, foi para **−2,388 ns**: 58 caminhos falhando, o dispositivo não podia ser gravado.

O diagnóstico veio antes de qualquer conserto, e foi ele que economizou o trabalho: dos 58 caminhos, **49 estavam no SHA-256 e 9 no AES**, e o pior do AES era −0,087 ns — ruído. Um único bloco respondia por tudo. E dentro dele, um único caminho: **oito somas de 32 bits encadeadas num ciclo só**, porque a expansão da mensagem e a rodada de compressão dividem o mesmo ciclo.

A correção foi registrar as duas entradas combinacionais da rodada, com um detalhe bonito: deslizar a janela da expansão uma rodada mais cedo faz os quatro *taps* andarem junto, e a mesma fórmula que produzia `W[t]` passa a produzir `W[t+1]`. Sem estágio de pipeline novo, sem ciclo a mais — ainda são 64 rodadas por bloco.

```
+0,637 ns   Fase 1, sem criptografia
−2,388 ns   com o CFS                          não fecha
−1,215 ns   com esforço máximo de ferramenta   não fecha
+0,487 ns   com os dois patches de retimagem   fecha
```

> ***A lição não é retimagem — é o que precisa existir antes de você poder tocar numa implementação criptográfica.***
>
> *Modificar um core de hash é a espécie de coisa que se faz errado em silêncio: o resultado continua parecendo um hash. O que tornou isto aceitável foi a rede de vetores oficiais montada antes — 65 mensagens do SHAVS, rodadas no core e através do barramento. Foi possível* ***provar*** *que a modificação não mudou o resultado, sem tocar num vetor e sem relaxar um assert.*
>
> *É a mesma razão de o FIPS 140-3 exigir self-test (seção 11) e de o projeto ter a regra "se um KAT falha, o bug está no código". Sem isso, mexer ali seria irresponsável — e é exatamente por não ter essa rede que "não invente sua própria criptografia" é um bom conselho.*

A modificação entrou como **patch versionado e revisável**, não como fork nem reescrita: `third_party/` continua byte a byte igual ao upstream, e o diff do que mudou está no repositório, legível, ao lado da justificativa.

Como a fase terminou, e a surpresa dela

O plano dizia que RCT e APT (seção 10) ficariam em **firmware**. Não dá, e descobrir por quê foi a lição da fase: a SP 800-90B exige que os testes *contínuos* vejam **toda** amostra, e a fonte produz uma por ciclo de 100 MHz. A CPU veria uma em mil.

A divisão que sobrou é melhor do que a planejada:

- **hardware** faz os testes contínuos, amostra a amostra, e congela um retrato de 1024 amostras brutas consecutivas;
- **firmware** faz os testes de partida sobre esse retrato e é dono da política — reprovou, o dispositivo vai para `TAMPERED`.

Os dois testes acabam implementados **duas vezes, de forma independente**, e uma discordância entre eles denuncia erro de interpretação da norma. Não foi custo: foi a verificação saindo de graça.

Cuidado térmico registrado no plano, e respeitado: meia dúzia de anéis osciladores, não centenas. Array grande gera calor e ruído de alimentação localizados sem ganho de entropia.

O **POST** (seção 11) roda antes de aceitar qualquer comando. Ao fim da Fase 2 ele cobria AES-256, SHA-256, HMAC-SHA-256, CMAC-AES-256, CTR_DRBG, os testes de partida da fonte e o key store — todos contra vetores oficiais — a um custo de **5,94 ms** de boot.

Falha leva a `TAMPERED`, e o dispositivo passa a atender **só** ao `SELFTEST`, que é o único jeito de o operador saber *o que* reprovou em vez de olhar um LED vermelho.

> ***O POST cresceu depois, e o número acima é o da Fase 2.*** *A Fase 3 acrescentou o key block X9.143 e a prova de zeroização; são oito testes, e o boot passou a custar cerca de* ***9 ms****. A série está em* `doc/fase3-notas.md`*, e vale menos pelo número do que pela forma: cada propriedade que o dispositivo passa a garantir sobre si mesmo cobra milissegundos de todo boot, para sempre.*

Da fase sobrou apenas `dieharder -a`, que não está instalado na máquina de trabalho — e que é sanidade estatística, não validação de gerador.

28. Fase 3 — hierarquia de chaves *(em andamento)*

O coração do projeto, e onde os conceitos das Partes II e III viram código.

- ✅ **Key store** com os campos do cabeçalho TR-31 modelados desde o início — refatorar isso depois é doloroso porque o MAC cobre o cabeçalho inteiro.
- ✅ **Cerimônia de LMK** com três componentes XOR, KCV a cada passo, e dual control exigindo os dois botões.
- ✅ **Máquina de estados** com o display de 7 segmentos soletrando `Uni` / `Aut` / `OPE` / `tPr`, mais o ponto decimal confirmando o dual control.
- ✅ **Key blocks ANSI X9.143 (TR-31 versão D)**: KBEK e KBAK derivadas por CMAC, corpo em AES-CBC, autenticação por CMAC sobre cabeçalho e corpo — escritos **duas vezes**, em C e em Python.
- ✅ **Zeroize** com prova — e a prova não vem de dump.
- ✅ **Comandos de chave**: gerar dentro da fronteira, exportar embrulhado, reimportar, consultar metadados. **Nenhum deles exige dual control**, e a razão está mais abaixo.
- **Apagar um slot isolado** — a função existe no firmware, o comando não. Só apareceu quando se tentou *usar* o dispositivo em laço, e não quando se planejou a fase.
- **Usar chave por handle** — os comandos de AES e HMAC da Fase 2 recebem a chave no pedido e, com chave mestra carregada, param de responder sozinhos. As versões por handle ainda não existem.
- **Log de auditoria** gravado antes da execução, em flash, com contador monotônico.

A cerimônia, e o que o dual control prova

A LMK entra em **três componentes** que se acumulam por XOR: cada custodiante carrega o seu e nenhum vê os demais, e nenhum componente isolado revela nada sobre a chave. A cada passo volta o KCV **do componente** — não do acumulado — para que quem digitou errado descubra na hora, e não no fim, quando já não dá para saber qual dos três estava trocado.

Os dois botões físicos autorizam, e há um detalhe que só aparece quando se tenta atacar o próprio mecanismo: **não basta que os dois estejam pressionados**. Entre uma autorização e a seguinte, os dois têm de ser vistos **soltos**. Sem essa exigência, fita adesiva sobre os dois botões carregaria a LMK inteira sozinha, e o dual control seria teatro — e, pior, um botão travado em "pressionado" passaria a autorizar tudo em vez de nada.

A escada de estados é de **uma via só**. Carregou os três componentes, o dispositivo vai a `AUTHORIZED` e o comando de carregar deixa de existir — não há caminho para trocar a chave mestra por cima da existente. Ativou, vai a `OPERATIONAL` e o comando de ativar some. Descer exige apagar.

O efeito colateral mais instrutivo é o que **desaparece**: em `OPERATIONAL` os comandos da Fase 2 que recebem chave em claro no payload param de responder. Nenhuma linha de código os desliga — a máscara de estados deles diz `UNINITIALIZED`, e o dispositivo simplesmente não está mais lá.

O painel, e uma pergunta de bancada que virou projeto

A cerimônia nasceu completa e **inoperável**: a ferramenta mandava "segure SW2 e SW5", e o operador não tinha como saber quais eram. Rótulo minúsculo, no meio de um procedimento, num par que o próprio projeto ainda não tinha confirmado.

O conserto óbvio — descrever os botões por posição em vez de por rótulo — resolveu metade. A outra metade veio de perguntar quem *deveria* responder isso, e a resposta é o dispositivo. O display de 7 segmentos estava ocioso desde a Fase 1, com a pinagem verificada e nada para exibir.

Agora ele soletra o estado, e o **ponto decimal acende enquanto o dual control está satisfeito**. O operador aperta e vê o dispositivo concordar, antes de gastar o comando. É a diferença entre uma autorização que se descobre pelo erro e uma que se confirma pelo gesto.

Duas notas de projeto:

- O display **não lê a máquina de estados**; ele recebe dois bits pelo GPIO. Um caminho de hardware até a estrutura de estado seria caminho de hardware até o que está ao lado dela na memória.
- O `default` do decodificador é `tPr`, não `Uni` nem apagado. Estado corrompido tem de aparecer como comprometido — falhar para o lado seguro vale também para o painel.

E há uma medida que faltava e ninguém tinha notado que faltava. A verificação de 2026-08-09 desenhou `222` nos três dígitos ao mesmo tempo, o que confirma polaridade e mapeamento de segmento — e **não distingue ordem**: três dígitos iguais são iguais em qualquer ordem. O experimento *parecia* ter coberto o display inteiro. Fechou desenhando `123`, com a varredura vindo do host, três comandos em laço.

O key block, e a pergunta que ele responde

Uma chave que nunca sai não serve para nada além de si mesma. O key block é a resposta para "como deixar uma chave sair **sem que ela vaze**" — que é um problema diferente de guardá-la, e mais difícil.

O formato é uma string de texto:

```
cabeçalho(16 caracteres) || corpo cifrado em hex || MAC em hex

D 0144 D0 A B 00 E 00 00
| |    |  | | |  | |  +-- reservado
| |    |  | | |  | +----- blocos opcionais
| |    |  | | |  +------- exportabilidade
| |    |  | | +---------- versão da chave
| |    |  | +------------ modo de uso
| |    |  +-------------- algoritmo
| |    +----------------- uso: dados, KEK, MAC, BDK…
| +---------------------- comprimento total
+------------------------ versão do formato
```

Três decisões dele valem mais que o código inteiro.

Duas chaves derivadas, não uma. A LMK não cifra o corpo nem autentica o bloco: dela saem duas filhas por CMAC, uma para cada trabalho, distinguidas por um campo de *propósito* na entrada da derivação. É a separação de chaves da seção 15 aplicada onde ela é mais fácil de esquecer — se as duas fossem a mesma, um oráculo de MAC seria um oráculo de cifragem de graça.

O cabeçalho vai dentro do MAC. São dezesseis bytes de texto legível, à vista de qualquer um — e autenticados. Sem isso, alguém que não consegue decifrar o corpo simplesmente **edita o caractere** da exportabilidade de `N` para `E` e devolve o bloco. O criptograma não mudou; a política mudou. É o ponto que resume a Parte II inteira: chave protegida sob metadado desprotegido não está protegida.

O MAC é o vetor de inicialização. Não há IV para transmitir, e o MAC é calculado sobre o texto **claro** — o que permite recusar um bloco adulterado *antes* de acreditar em qualquer campo do que se decifrou.

E o enchimento aleatório no fim do corpo não é sobra: sem ele, o tamanho do bloco denunciaria o tamanho da chave, e "esta é uma chave de 128 bits" já é informação para quem escolhe onde gastar esforço.

Por que o mesmo formato foi escrito duas vezes

Uma implementação em C, dentro do dispositivo; outra em Python, no host, sobre uma biblioteca diferente. Não é redundância — é o **método de verificação**.

Um formato binário se aprende errado em silêncio: a implementação lê a norma, se convence, e testa contra si mesma. Duas implementações escritas para discordar não têm essa saída, e a menor divergência aparece como MAC inválido, que é barulhento e imediato. Se as duas compartilhassem o AES, concordariam sobre um erro no AES sem nunca discordar — daí a exigência de bibliotecas diferentes.

E aqui aparece um limite que vale enunciar, porque ele explica de onde vem a confiança em cada camada. **Não existe vetor oficial para este formato.** O programa de validação do NIST valida *algoritmo*; X9.143 é *formato*, e a norma que traz o exemplo é paga. O que se usa é um valor conhecido de terceiros, e o resto da confiança vem de propriedades: ida e volta, e um bit trocado em **cada posição do bloco** tendo de invalidar tudo.

Esse último é o teste que vale mais que os outros. Uma implementação que esqueceu de incluir o cabeçalho no MAC passa no vetor e passa na ida e volta. Falha só ali.

Apagar, e provar que apagou

"Chamei a função de apagar" não é a mesma coisa que "apagou", e a diferença é invisível de fora. Um `wipe` que o compilador eliminou por ser escrita morta, um campo novo que ninguém acrescentou ao laço, um índice fora do intervalo: os três falham em **silêncio** e deixam chave viva num dispositivo que se anuncia limpo.

O problema é que a verificação óbvia — o firmware varrer a própria memória — é **auto-atestação**: é o mesmo código dizendo que o mesmo código funcionou. Ela vale (e roda a cada boot), mas não fecha a pergunta.

O que fecha é usar **criptografia para provar memória**. A chave mestra se acumula por XOR dos três componentes. Se a zeroização deixasse um único bit para trás, a cerimônia seguinte acumularia sobre o resíduo — e o KCV resultante não seria o dos componentes. Então o teste é: cerimônia, KCV esperado; apagar; **mesma cerimônia, e o KCV tem de voltar a bater**. E o valor esperado não é "o que o dispositivo devolveu da outra vez": é um vetor oficial do NIST.

Nenhum firmware passa nesse teste sem que a memória estivesse mesmo zerada.

Duas notas de projeto, e a segunda é a mais instrutiva:

- **A sobrescrita é em duas passadas**, um padrão e depois zeros. Para memória estática a segunda é a que conta — dizer o contrário seria repetir folclore de disco magnético. A primeira existe porque uma zeroização **interrompida** tem de deixar padrão, não meia chave.
- **O comando exige dois operadores; o gatilho automático não exige ninguém.** Apagar é destrutivo, então uma pessoa não basta. Mas quando é o próprio dispositivo que se descobre comprometido, exigir autorização seria absurdo: bastaria não haver ninguém na sala para a chave sobreviver ao comprometimento. A assimetria não é inconsistência — é o reconhecimento de que as duas situações têm ameaças opostas.

E há um detalhe que a máquina de estados resolve de graça: apagar em `TAMPERED` funciona, e **não tira** o dispositivo de `TAMPERED`. A chave vai embora, que era o pedido; o veredito fica, porque um HSM que se cura de tamper não detectou tamper nenhum.

Os comandos de chave, e por que nenhum pede dois dedos

Depois da cerimônia vem o trabalho: gerar uma chave, exportá-la embrulhada, reimportá-la, consultar o que ela é. Quatro comandos, e **nenhum deles exige dual control** — o que contraria a intuição o suficiente para valer o parágrafo.

Dual control é para cerimônia, não para operação. Carregar a chave mestra, ativar o dispositivo e apagar tudo são eventos raros, com gente na frente do equipamento. Gerar e exportar chave é o que um HSM faz o dia inteiro. Exigir dois dedos ali não aumentaria segurança nenhuma — garantiria apenas que ninguém usa o equipamento. E um controle que impede o uso legítimo é desligado no primeiro dia ruim, junto com os que serviam para alguma coisa.

O que protege esses quatro é estrutural, não humano:

- a chave **nunca sai em claro** — sai embrulhada num key block, e quem recebe não sabe abrir;
- o key block é **autenticado sobre cabeçalho mais corpo**, então a política viaja junto com a chave e não pode ser reescrita a caminho;
- `exportabilidade` decide quem pode sair, e existe **um único caminho** no código para os bytes deixarem um slot — é ele que consulta o campo.

A última linha é a diferença entre uma regra e uma promessa. Se houvesse duas formas de obter os bytes, a verificação viraria convenção — e convenção é o que se esquece no caminho raro.

O contraste que fecha a Parte II. Na Fase 2, o comando de cifrar recebia a chave *no pedido*, vinda do host. Na Fase 3 o host escolhe os **metadados** e nunca vê o material. Os dois não podem coexistir num dispositivo com chave de verdade — e não coexistem, sem uma linha de código desligando nada: a máscara de estados dos comandos antigos diz `UNINITIALIZED`, e no instante em que existe uma chave mestra eles somem.

E uma decisão que só parece detalhe: **toda recusa de importação devolve o mesmo código**. Bloco malformado, hexadecimal inválido, MAC errado e comprimento impossível são indistinguíveis de fora. É o comando mais exposto do dispositivo — um atacante manda blocos forjados em laço e cada resposta é informação. Dizer em qual etapa a validação parou é o oráculo de padding da seção 15, com outra roupa: o atacante não precisa da chave, precisa que a vítima seja prestativa.

Uma lição de ferramenta, que valeu mais que o comando

As duas sabotagens deliberadas do mecanismo de apagar — quebrar o código de propósito para ver se o teste reprova — **passaram**. Não porque o teste fosse fraco: porque o script de simulação não recompilava o firmware. Ele conferia que a imagem existia e seguia adiante, então o testbench validava o binário anterior.

Um teste que nunca vê o código em teste é pior que teste nenhum, e essa classe de falha não aparece em revisão de código — só aparece quando se tenta, de propósito, fazer o teste falhar.

É a razão de a disciplina de sabotagem existir. Ela não confirma que o código está certo; ela confirma que o **teste está ligado**.

E a honestidade que fecha a seção: num HSM de verdade o componente entra por teclado local ou cartão do custodiante, **nunca pela mesma porta por onde o host fala**. Aqui a porta é uma só, e o componente atravessa o link em claro. É a maior distância entre este projeto e o modelo — e está escrita, não escondida.

O critério de aceitação que mais importa:

> *Captura da UART durante toda a suíte não contém nenhum byte de chave em claro — `grep` automatizado contra as chaves conhecidas do teste.*

É a fronteira criptográfica deixando de ser afirmação e virando medida (seção 5).

Outros critérios: gerar chave, exportar em TR-31, reimportar e usar em AES com resultado idêntico; parser Python e firmware C concordando em 100 blocos aleatórios; alterar um bit do cabeçalho ou do corpo invalidando o MAC; e chave marcada como não exportável não saindo **por caminho nenhum**.

29. Fase 4 — armazenamento não-volátil *(em andamento)*

Até a Fase 3, desligar a placa apagava tudo: a LMK, as chaves e o estado. Cada sessão de bancada começava digitando três componentes de 64 caracteres. Um HSM comercial não se comporta assim. Ele desliga e volta *online* com a chave mestra e as chaves de trabalho, e é esse comportamento que a Fase 4 reproduz.

A decisão que a fase tomou, e por que ela é fraca de propósito

Num HSM comercial, a LMK sobrevive ao desligamento numa **memória mantida por bateria, dentro de um invólucro com detecção de violação** (§18.2). Abrir a caixa corta a bateria, e a chave some.

Esta placa não tem nada equivalente. O eFUSE é proibido pela regra nº 1, a BBRAM está sem bateria, o DNA do chip é público e não há invólucro. Embrulhar a LMK antes de gravá-la só mudaria o problema de lugar: a chave que a embrulha teria de ficar guardada em algum lugar, e esse lugar seria a mesma flash.

Então, por ser um projeto **educacional** e diante dessa **limitação de hardware**, a decisão (do autor, em 2026-10-15) foi:

> *A região da flash SPI a partir de 4 MB é **tratada como memória segura**. A LMK é guardada nela em claro; as chaves de trabalho, embrulhadas sob a LMK como key blocks X9.143.*

O comportamento operacional fica igual ao de um equipamento comercial. A proteção física não fica: quem tiver um gravador SPI lê a LMK. A diferença está escrita em `doc/fase4-notas.md`, em vez de disfarçada por um esquema que pareceria proteger e não protegeria.

O que entrou

- **Hardware.** O SPI do NEORV32 fala com a mesma flash que guarda o bitstream. O clock passa pela primitiva `STARTUPE2`, a única forma de a lógica do usuário alcançar o pino de clock de configuração. As memórias do processador dobraram (32 KB de código, 16 KB de dados). Custo: +83 LUTs, +6 Block RAMs, e a folga de timing ficou praticamente igual (+0,258 ns).
- **A guarda do bitstream.** O driver recusa apagar ou gravar abaixo de 4 MB, num lugar só, por onde toda escrita passa.
- **O registro persistente**, com a LMK, o estado e os slots, em **duas cópias**. Cada gravação vai para a mais velha, e uma queda de energia no meio deixa a outra intacta. No boot vale a mais nova cujo

CRC confere.

- **Chave anunciada é chave guardada.** Se a flash falhar, `GEN_KEY` e parentes desfazem o slot e devolvem `STORE_FAIL`.
- **O log de auditoria**, finalmente (§5 do plano). Cada comando é registrado **antes** de executar, com o resultado "pendente"; depois só o byte de resultado é programado por cima. Um registro que ficou pendente é um comando que começou e não terminou. E se o log não puder ser gravado, o comando não executa. A exceção é o `ZEROIZE`.

O que ficou de fora, de propósito

O plano previa um **contador anti-rollback**. O problema é real: quem restaurar uma imagem antiga da flash ressuscita uma chave apagada. Mas a defesa exige um contador monotônico **fora** da flash, que a placa não tem, e um contador dentro dela seria restaurado junto com o resto. A limitação está documentada, não mitigada. É um dos pontos onde HSMs reais gastam esforço desproporcional, e aqui fica como lição, não como código.

30. Fase 5 — API de host *(em andamento)*

Decidida em favor de um command set ASCII no estilo dos HSM de pagamento — código de comando de dois caracteres, código de resposta igual ao comando mais um, erros numéricos, campos posicionais — e não de um subconjunto de PKCS#11 como biblioteca compartilhada.

Não é troca de sintaxe. PKCS#11 é uma API de *biblioteca*: objetos, sessões, atributos, estado do lado do cliente. Um command set de HSM de pagamento é um protocolo de *serviço*, sem sessão e sem estado — **cada comando chega sozinho e precisa se bastar**. Isso muda o que o dispositivo tem de verificar, e muda para pior: não há contexto acumulado em que confiar.

É aqui que se entende por que a API é o que é: **é você que precisa impedi-la de vazar material de chave**. Depois de ter lido a seção 15, escrever a API com a pergunta "o que isto vaza em laço?" na cabeça é uma experiência diferente.

As três decisões com que a fase começou

Quem interpreta o ASCII é o dispositivo. No computador fica só uma ponte que liga um socket TCP à UART e repassa os bytes sem entendê-los. A outra opção — um programa no PC traduzindo o ASCII para o protocolo binário — seria mais rápida de escrever e ensinaria a coisa errada: a defesa da API ficaria fora da fronteira criptográfica, que é justamente o lugar onde ela não protege nada.

Console e host passam a ter papéis separados. O protocolo binário das fases anteriores vira o *console*: cerimônia, estado, diagnóstico, log. O ASCII é o *host*, e não tem nenhum comando de cerimônia — quem opera não administra. Os dois dividem a mesma UART (o primeiro byte de cada mensagem diz qual é qual), então a separação é de papéis, não física; a distância em relação a um equipamento comercial, que tem portas separadas, continua registrada.

A chave de trabalho viaja no comando. Esta é a mudança de modelo mental da fase. Até aqui o dispositivo guardava as chaves em 16 slots e o host as citava por número. Um HSM de pagamento não funciona assim: ele não guarda as chaves de trabalho de ninguém. O sistema do cliente as mantém no

banco de dados dele, cada uma como um key block embrulhado sob a LMK, e manda o bloco junto com cada pedido. O dispositivo abre o bloco por dentro, usa a chave e a esquece **antes de responder**.

É por isso que um equipamento com memória para poucas chaves atende milhões delas, e é por isso que a LMK é a única chave que ele precisa guardar. A frase "sem estado" do parágrafo anterior quer dizer exatamente isto: o estado existe, mas mora do lado do cliente, embrulhado.

O que já entrou

Sete comandos, com códigos deste projeto (da categoria vem só a forma geral): diagnóstico, gerar chave, conferir um key block, cifrar e decifrar em AES-CBC, gerar e verificar CMAC. A chave de cada comando é aberta num slot **efêmero** do key store — o mesmo código de sempre faz a checagem de modo de uso — e apagada ao fim do comando, em qualquer desfecho. O apêndice B tem o formato.

O que vem depois, na mesma fase: exportar e importar sob uma chave de troca que não seja a LMK, que é o que qualifica a exportação.

31. Fase 6 — tamper e ataques

Duas metades.

Defesa: XADC monitorando temperatura e tensão, disparando zeroize fora de faixa. É o mecanismo de proteção contra falhas ambientais do FIPS nível 4 (seção 19), em versão mínima.

Ataque: atacar o próprio HSM. Glitch de clock pela porta de reconfiguração dinâmica do MMCM, observar a assinatura sair errada, e então implementar contramedidas — dupla execução, verificação de resultado (seção 17.4).

Também: bitstream encriptado com chave em BBRAM, como confidencialidade de firmware. E o experimento de RO-PUF, documentado à parte, que mede na própria placa **por que** um PUF de FPGA é ruim e por que o corretor de erros é obrigatório.

Esta é a fase mais divertida e a mais instrutiva: construir, quebrar, reforçar.

32. Fase 7 — assimétrico

RSA-2048 por Montgomery nos 90 DSP48E1; P-256 depois.

Deixado por último de propósito: o aprendizado de arquitetura de HSM está nas fases 3 a 5. E há um gancho direto com a seção 17.1 — implementar RSA-CRT sem verificar a assinatura antes de emitir é reproduzir o ataque Bellcore no próprio equipamento.

33. Fase 8 — criptografia de pagamento

Acrescentada ao plano em 2026-08-08, quando o modelo de referência do projeto passou a ser a categoria dos HSMs de pagamento. É a última porque depende de tudo o que vem antes: sem hierarquia de chaves (Fase 3) e sem API de serviço (Fase 5), não há onde encaixar um comando de tradução de PIN.

O conteúdo dela é a **Parte VII** deste manual. O que decide se um item é implementável aqui não é a dificuldade — é o **hardware** e a **procedência dos vetores**:

- o que é AES cabe (PIN block formato 4, DUKPT AES);
- o que é inerentemente 3DES não cabe, porque o coprocessador é AES-256 sem caminho de downgrade, e isso é decisão de arquitetura e não tarefa pendente;
- o que não tem vetor público não entra, ou entra marcado como não verificado — a regra nº 5 exige procedência, e "implementei e parece certo" é exatamente o que ela proíbe.

O melhor item da lista é o **ataque de tabela de decimalização** (seção 37.3), e por um motivo que vale registrar: ele não precisa de 3DES nem de vetor de bandeira nenhuma. O ataque é sobre a **API**, não sobre a cifra, e reproduz inteiro num esquema nosso com AES.

34. Ordem de trabalho, e a regra que a sustenta

Uma regra vale para todas as fases:

> ***Nada vai para a placa sem passar antes no testbench.***

Depurar criptografia por UART, no hardware, sem visibilidade interna, é a forma mais lenta possível de descobrir que faltou um byte no preenchimento. Um erro de enquadramento em simulação custa segundos; o mesmo erro na bancada custa uma tarde e várias hipóteses erradas.

A Fase 1 já demonstrou o retorno: dois defeitos reais foram pegos em simulação, e o único que escapou até o hardware foi o único que a simulação estruturalmente não podia ver.

Parte VII — Criptografia de pagamento

Esta parte existe porque o modelo de referência deste projeto passou a ser um **HSM de pagamento comercial**. Entender o que esses equipamentos fazem o dia inteiro é o que separa "sei o que é uma fronteira criptográfica" de "sei por que aquele comando existe".

Aviso que vale para o capítulo inteiro: **este projeto não implementa nada do que está aqui.** A seção 39 explica o que dele é implementável e o que não é, e por quê. O material abaixo é para entender o domínio, não para copiar em código.

> ***Independência e fontes.*** *Este capítulo* ***não nomeia fabricante nem produto****, de propósito. O modelo de estudo é a categoria — HSM de pagamento — e nada aqui alega vínculo, endosso ou compatibilidade com equipamento comercial algum.*
>
> *Todo o conteúdo vem de* ***normas públicas*** *(ISO 9564, ANSI X9.24 e X9.143, NIST SP 800-38B) e de* ***literatura acadêmica publicada****. Nada é derivado de documentação proprietária: tabela de comandos, código de erro e esquema de chave de manual de fabricante são material licenciado e* ***não entram aqui****.*

> ***Sobre os layouts de bytes.*** *Descrevo a estrutura e o porquê de cada construção, não o mapa exato de nibbles. Isso é deliberado: os layouts normativos estão na ISO 9564, na ANSI X9.24 e nas especificações das bandeiras, e a regra deste projeto proíbe escrever valor normativo de memória. Quem for implementar tem de ler a norma — e essa é a lição, não um contratempo.*

---

35. PIN blocks — por que um PIN não viaja sozinho

Um PIN de quatro dígitos tem 10.000 valores possíveis. Cifrar isso diretamente com uma chave, sozinho, é um desastre: o mesmo PIN produz sempre o mesmo criptograma, e um dicionário de 10.000 entradas quebra tudo em tempo nenhum.

A solução é o **PIN block**: um bloco de tamanho fixo que combina o PIN com o **número da conta** (PAN) antes de cifrar. Duas consequências, e as duas importam:

1. O criptograma de um mesmo PIN é **diferente para cada conta**. O dicionário morre.
2. O PIN block fica **amarrado à conta**. Um PIN block capturado numa transação não serve para outra conta — pelo menos é essa a intenção.

A ISO 9564-1 padroniza vários formatos. Interessam três.

35.1 Formato 0 (ANSI X9.8) — o que existe em todo lugar

O mais antigo e o mais difundido. A ideia:

```
campo do PIN   comprimento + digitos do PIN + preenchimento fixo
campo do PAN   parte do numero da conta, alinhada
PIN block      cifra( campo_PIN  XOR  campo_PAN )
```

Bloco de 64 bits, porque nasceu para DES.

Onde ele é fraco, e não é na cifra:

- **O preenchimento é fixo.** Sabendo o formato, o atacante conhece boa parte do bloco em claro antes de começar.
- **O bloco não é autenticado.** Nada prova que aquele PIN block é o que o emissor mandou. Autenticidade vem de fora, se vier.
- **64 bits é pouco.** Com DES, o tamanho de bloco vira problema estatístico antes de o tamanho de chave virar.
- **O PAN é fornecido por quem chama.** Esta é a pior. Se o atacante controla o PAN que entra no XOR, ele controla metade do bloco — e é daí que saem os ataques de tradução da seção 15.3.

35.2 Formato 1 — quando não há conta

Usa preenchimento **aleatório** e não inclui o PAN. Existe para o caso em que o número da conta não está disponível no momento de formar o bloco.

O preço é exatamente o que o formato 0 comprava: **o bloco não está amarrado a conta nenhuma**. Um PIN block formato 1 capturado vale para qualquer conta que aceite formato 1. Por isso ele é restrito a trechos onde outra coisa garante o vínculo.

35.3 Formato 3 — o remendo intermediário

Como o formato 0, mas com preenchimento **aleatório** em vez de fixo. Tapa o buraco do "atacante já conhece metade do bloco" sem mexer no resto. Continua com bloco de 64 bits e continua não autenticado.

35.4 Formato 4 — o de AES, e o único que este projeto poderia fazer

Reprojetado para AES, bloco de 128 bits. A estrutura tem **duas passagens de cifra**, e é isso que importa:

```
bloco A   controle + comprimento + digitos do PIN + preenchimento ALEATORIO
bloco B   campo do PAN, alinhado em 128 bits

intermediario = AES( K, bloco A )
bloco C       = intermediario XOR bloco B
PIN block     = AES( K, bloco C )
```

Compare com o formato 0, que é **uma** cifra sobre um XOR. A diferença não é cosmética:

- No formato 0, controlar o campo do PAN é controlar diretamente a entrada da cifra. No formato 4, o XOR com o PAN acontece **depois** de uma passagem de AES — o atacante não controla mais a entrada, controla a entrada de uma função que ele não sabe inverter.
- O preenchimento aleatório faz o mesmo PIN, na mesma conta, produzir blocos diferentes a cada vez.
- 128 bits de bloco elimina o problema estatístico do DES.

Este é o único formato que este projeto poderia implementar de verdade, porque é o único que usa AES — e AES é o que existe no fabric.

---

36. Tradução de PIN — o comando mais perigoso que existe

Uma transação com cartão atravessa domínios de chave diferentes: terminal, adquirente, bandeira, emissor. Cada domínio tem a sua chave. O PIN precisa chegar do primeiro ao último **sem nunca aparecer em claro fora de um HSM**.

Quem faz isso é a **tradução de PIN block** — o comando `CA` de um de pagamento. Ele:

1. recebe o PIN block cifrado sob a chave de entrada,
2. decifra **dentro** da fronteira,
3. recifra sob a chave de saída (possivelmente noutro formato),
4. devolve o novo PIN block.

O PIN existe em claro por microssegundos, dentro do módulo, e nunca sai.

Por que é o comando mais perigoso: ele é, por construção, um oráculo. O chamador escolhe as chaves, escolhe o PAN, escolhe os formatos, e observa se a operação teve sucesso. Todos os ataques da seção 15.3 nascem daí — o módulo nunca revela o PIN, revela apenas *se deu certo*, e isso basta quando se pode perguntar milhares de vezes.

Se você entender um único comando de HSM de pagamento a fundo, que seja este.

---

37. Verificação de PIN — PVV e IBM 3624

O emissor precisa decidir se o PIN digitado está certo. Guardar os PINs numa base seria insano, então guarda-se um **valor derivado** de quatro dígitos, e a verificação recalcula e compara.

Duas famílias dominam.

37.1 PVV (Visa)

Combinam-se dígitos do PAN, um índice de chave e o PIN; cifra-se o conjunto com um par de chaves PVK; **decimaliza-se** o resultado; guardam-se quatro dígitos. Para verificar, o emissor refaz a conta com o PIN apresentado e compara.

Repare no que ele **não** faz: não guarda o PIN e não permite recuperá-lo. Quatro dígitos de PVV não determinam o PIN — várias entradas colidem, e é proposital.

37.2 IBM 3624 e o *offset*

Cifra-se um dado de validação derivado do PAN, decimaliza-se, e obtêm-se alguns dígitos: o **PIN natural**. Como o cliente quer escolher o próprio PIN, guarda-se o **offset** — a diferença dígito a dígito, módulo 10, entre o PIN escolhido e o natural.

O offset **não é secreto**: ele pode ser impresso, transportado, guardado em claro. Sem a chave, ele não diz nada sobre o PIN.

37.3 A decimalização, e por que ela é o ponto fraco

Cifrar produz **hexadecimal**. PIN é **decimal**. A ponte entre os dois é uma tabela:

```
hex:    0 1 2 3 4 5 6 7 8 9 A B C D E F
tabela: 0 1 2 3 4 5 6 7 8 9 0 1 2 3 4 5
```

Essa tabela, que parece detalhe de formatação, é a origem do ataque mais instrutivo da literatura de HSM — **Bond e Zieliński, 2003**. Algumas APIs deixavam o *chamador* fornecê-la. Fornecendo tabelas degeneradas e observando apenas "verificou / não verificou", recupera-se um PIN de quatro dígitos em cerca de **quinze chamadas**, contra cinco mil de força bruta.

O ataque está detalhado na **seção 15.2**. Aqui só o alerta que ele deixa:

> *Um parâmetro que parece configuração inofensiva pode ser a superfície de ataque inteira.*

E é por isso que o checklist deste projeto pergunta, para todo comando novo, *o que ele vaza se for chamado em laço com entradas escolhidas*.

---

38. DUKPT — uma chave por transação

Imagine um milhão de terminais em campo. Se todos compartilham a mesma chave, um terminal aberto na bancada de alguém compromete a rede inteira. Se cada um tem chave própria, é preciso distribuir e gerenciar um milhão de chaves.

DUKPT (*Derived Unique Key Per Transaction*) resolve os dois de uma vez:

- Existe uma **BDK** (*Base Derivation Key*), que fica só no HSM do adquirente e **nunca vai para o terminal**.
- Cada terminal recebe, na personalização, uma chave inicial derivada da BDK com o identificador dele.
- A cada transação, o terminal deriva uma **chave nova** e **apaga a anterior**.
- O terminal envia o **KSN** (*Key Serial Number*) — identificador do dispositivo mais um contador de transação. Com o KSN e a BDK, o HSM do adquirente rederiva exatamente a mesma chave.

As três propriedades que isso compra:

1. **Compromisso isolado.** Abrir um terminal não dá nada sobre os outros.
2. **Sigilo do passado.** As chaves usadas já foram apagadas no terminal; quem o abrir agora não decifra o que passou por ele ontem.
3. **Nada para distribuir.** O HSM rederiva; não existe base de um milhão de chaves para sincronizar.

38.1 X9.24-1 (TDES) e X9.24-3 (AES)

	TDES DUKPT (X9.24-1)	AES DUKPT (X9.24-3)
Cifra	3DES de duas chaves	AES-128/192/256
Registradores de chave futura	21	32
Derivação	esquema próprio, histórico	função de derivação uniforme
Situação	legado, em desativação	o caminho adiante

A variante AES não é só "a mesma coisa com outra cifra": a derivação foi reescrita para ser uniforme e para suportar chaves de propósitos diferentes a partir da mesma raiz — separação de chaves construída no esquema, em vez de convencionada por fora.

A variante AES é implementável neste projeto. A TDES não, e o motivo é o assunto da próxima seção.

---

39. O que este projeto pode e o que não pode ensinar

A separação não é por dificuldade. É por **hardware** e por **procedência de vetor de teste**.

Assunto	Aqui?	O que decide
PIN block formato 4	**sim**	é AES, e AES é o que existe no fabric
PIN block formato 0 e 3	**estrutura sim**	a construção e as fraquezas se ensinam; a cifra real é DES
Tradução de PIN	**sim**	o valor está no formato do comando e no oráculo, não na cifra
Ataque de decimalização	**sim, e é o melhor item**	é ataque de **API**. Reproduz-se num esquema com AES, sem 3DES e sem vetor de bandeira
DUKPT AES (X9.24-3)	**sim**	cabe no hardware AES-only
CVV / CVC	**não**	inerentemente 3DES; não há variante AES em uso
PVV	**não**	idem — mas o *ataque* sobre ele se ensina sem ele
DUKPT TDES (X9.24-1)	**não**	idem

39.1 Um HSM precisa de 3DES?

A resposta depende de qual HSM, e a diferença ensina mais que a resposta.

HSM de propósito geral, hoje: não. O NIST desautorizou o TDEA para *cifrar* a partir de 2024 (SP 800-131A Rev. 2). Ele sobrevive apenas como algoritmo de **decifração legada** — para abrir o que foi cifrado antes. Projeto novo usa AES, e um módulo que ofereça 3DES para cifrar dados novos está oferecendo um pé no passado.

HSM de pagamento em produção: sim, na prática. Um módulo sem 3DES não conversa com a rede. PIN blocks sob ZPK de 3DES, PVV e CVV sob chaves 3DES, terminais DUKPT TDES aos milhões em campo — tudo isso existe agora, em operação, movendo dinheiro. Um módulo que só faça AES é inútil como substituto de um que está instalado.

E aqui está o ponto que vale o capítulo: a migração para key blocks e para AES foi mandatada em fases pelo PCI e levou **mais de uma década**. Não porque AES seja difícil, mas porque trocar criptografia numa rede com milhões de pontas não é decisão técnica — é logística, contrato e prazo regulatório. Terminal em campo não se atualiza por vontade; norma de mensagem não muda sozinha; e cada elo da cadeia precisa aceitar o novo formato *antes* que o anterior possa ser desligado.

É por isso que criptografia obsoleta sobrevive tanto em pagamentos. Não é descuido: é o custo real de mover um ecossistema.

Este projeto: não, e a ausência é conteúdo. Não há requisito de interoperar com ninguém, então não há a pressão que mantém o 3DES vivo lá fora. A restrição vira lição em vez de limitação.

39.2 Por que não há 3DES aqui

Não é omissão: é decisão registrada. O coprocessador deste projeto amarra o tamanho de chave em **AES-256, sem caminho para AES-128** — porque um modo mais fraco alcançável por escrita em registrador é um *downgrade* de graça para quem tomar o barramento. Acrescentar um núcleo DES contradiz esse princípio no mesmo bloco.

É defensável ter um motor legado, separado e rotulado como tal — que é honestamente o que um HSM de pagamento real tem, porque o mundo ainda roda 3DES. Mas é escolha consciente, e fica para quando a fase chegar.

39.3 O obstáculo maior são os vetores

A regra inviolável deste projeto diz que, se um teste de resposta conhecida falha, **o erro está no código, não no vetor** — e isso só vale se a procedência do vetor for verificável por terceiros. AES, SHA, HMAC, CMAC e CTR_DRBG têm vetores públicos do NIST e do IETF, com hash registrado.

Criptografia de pagamento não tem esse luxo. Os vetores da ANSI X9.24-3 estão atrás de paywall; os de CVV e PVV vivem em documentação de bandeira e em manual de fabricante. Sem vetor autoritativo não há KAT, e "implementei e parece certo" é exatamente o que a regra existe para proibir.

Consequência prática: onde não houver vetor público, o item não entra — ou entra explicitamente marcado como não verificado. Preferir a lacuna honesta à cobertura fingida é o mesmo critério que orienta o resto do documento.

39.4 Uma regra que não se negocia

⚠ **Nenhum número de cartão real, nunca.** Pela mesma razão que nenhuma chave de produção. Gerar CVV ou PIN para um PAN que existe deixa de ser exercício, e o fato de o dispositivo ser de brinquedo não muda isso.

Apêndices

A. Glossário

APT — *Adaptive Proportion Test*. Teste de saúde de fonte de entropia (SP 800-90B) que dispara quando um valor domina uma janela de amostras.

BBRAM — memória volátil do FPGA onde pode ficar a chave de decifra do bitstream. Perde conteúdo sem alimentação, e por isso é recuperável — ao contrário do eFUSE.

BDK — *Base Derivation Key*. Chave de pagamentos da qual se derivam chaves de terminal, tipicamente por DUKPT.

CFS — *Custom Functions Subsystem*. Slot do NEORV32 projetado para receber coprocessadores do usuário. É onde AES e SHA entram na Fase 2.

CMAC — código de autenticação de mensagem baseado em cifra de bloco. Usado no TR-31 para autenticar cabeçalho e corpo, e para derivar KBEK/KBAK.

CMVP — programa NIST/CCCS que valida módulos contra a FIPS 140-3.

CSP — *Critical Security Parameter*. Termo da FIPS para qualquer segredo cuja divulgação compromete a segurança: chave em claro, dado de autenticação, estado do gerador.

Dual control — nenhuma operação sensível pode ser realizada por uma pessoa sozinha. Ver seção 7.

DRBG — *Deterministic Random Bit Generator*. Gerador determinístico semeado por entropia física, especificado na SP 800-90A.

CVV / CVC — três dígitos derivados de PAN, validade e código de serviço sob um par de chaves. Inerentemente 3DES, e por isso fora do alcance deste projeto (seção 39).

Decimalização — mapear os dígitos hexadecimais que uma cifra produz para dígitos decimais, para formar um PIN. A tabela que faz esse mapeamento foi a origem do ataque de Bond e Zieliński (seções 15.2 e 36.3).

DUKPT — *Derived Unique Key Per Transaction*. Esquema em que cada transação usa uma chave distinta derivada de uma BDK, identificada por um KSN. Duas normas: X9.24-1 (TDES, legado) e X9.24-3 (AES). Seção 37.

eFUSE — memória de programação única do FPGA. **Proibida neste projeto**: erro vira brick permanente.

EAL — *Evaluation Assurance Level*, do Common Criteria. Mede o rigor da avaliação, **não** a força da segurança.

Fronteira criptográfica — o limite físico e lógico dentro do qual material de chave em claro existe. Ver seção 5.

KAT — *Known Answer Test*. Vetor de teste com entrada e saída conhecidas, usado nos autotestes.

KBEK / KBAK — chaves de cifra e de autenticação de key block, derivadas da LMK por propósito.

KCV — *Key Check Value*. Três bytes do resultado de cifrar um bloco de zeros com a chave. Permite verificar sem revelar.

KSN — *Key Serial Number*. Identificador do dispositivo mais o contador de transação, enviado junto com cada transação DUKPT. Com ele e a BDK, o HSM rederiva a chave usada. Seção 37.

KEK — *Key Encryption Key*. Chave cuja função é proteger outras chaves.

LMK — *Local Master Key*. A chave mestra do módulo, no topo da hierarquia. Nunca sai, nem embrulhada.

MMCM — *Mixed-Mode Clock Manager*. Bloco do FPGA Xilinx que sintetiza clocks. Aqui, 50 → 100 MHz.

PAN — *Primary Account Number*. O número do cartão. Entra na formação do PIN block para amarrar o PIN à conta. **Nunca usar um PAN real neste projeto** (seção 39.4).

PIN block — formato que combina PIN e número da conta para transporte. Os formatos da ISO 9564 e suas fraquezas estão na seção 35; os ataques clássicos, na 15.3.

PVV — *PIN Verification Value*. Quatro dígitos derivados de PAN e PIN sob uma chave PVK, guardados pelo emissor no lugar do PIN. Seção 36.1.

PMP — *Physical Memory Protection*. Mecanismo RISC-V de restrição de acesso à memória por região.

POST — *Power-On Self-Test*. Bateria de KAT executada no boot, antes de aceitar comandos.

PUF — *Physically Unclonable Function*. Raiz de confiança derivada de variações de fabricação, em vez de armazenada.

RCT — *Repetition Count Test*. Teste de saúde que dispara na repetição excessiva de uma amostra.

Split knowledge — nenhuma pessoa conhece uma chave inteira; ela é montada de componentes.

Tamper-evident / resistant / responsive — a escada de proteção física. Ver seção 18.1.

Tradução de PIN — decifrar um PIN block sob uma chave e recifrá-lo sob outra, sem que o PIN saia da fronteira. É o comando mais perigoso de um HSM de pagamento, porque é um oráculo por construção. Seção 35.

TR-31 — formato de key block da indústria de pagamentos, hoje ANSI X9.143. É o formato adotado por este projeto (seção 8).

TRNG — gerador de números aleatórios verdadeiro, baseado em fenômeno físico.

Zeroização — destruição de material de chave de forma verificável. Ver seção 12.

B. Especificação do protocolo

Implementado em `fw/src/cmd.c` (firmware) e `host/hsmtool.py` (host).

Enquadramento

```
pedido    LEN(2) | CMD(1)    | PAYLOAD | CRC32(4)
resposta  LEN(2) | STATUS(1) | PAYLOAD | CRC32(4)
```

- Todos os campos multi-byte em **big-endian**.
- `LEN` cobre `CMD` / `STATUS` + `PAYLOAD`. Não se inclui nem inclui o CRC.
- `LEN` válido: 1 a 513 (payload máximo de 512 bytes).
- **CRC32** cobre `LEN` + `CMD` / `STATUS` + `PAYLOAD` — todos os bytes menos os quatro dele próprio. Polinômio IEEE 802.3 refletido (`0xEDB88320`), inicialização `0xFFFFFFFF`, xor final `0xFFFFFFFF`. Idêntico ao `zlib.crc32` do Python.
- Timeout entre bytes no dispositivo: 250 ms. Timeout de resposta no host: 2 s.

Comandos da Fase 1

Opcode	Nome	Payload do pedido	Payload da resposta
`0x01`	`PING`	vazio	`"PONG"`
`0x02`	`GET_VERSION`	vazio	major, minor, patch, estado
`0x03`	`GET_DNA`	vazio	8 bytes: identidade do die, 57 bits big-endian

O `GET_DNA` ficou respondendo `NOT_IMPLEMENTED` durante toda a Fase 1 e só fechou com o CFS da Fase 2 (seção 27) — o `DNA_PORT` é primitiva Xilinx e precisava de um caminho até a CPU. O valor **não é segredo**: qualquer um com um cabo JTAG lê o mesmo número, e ele nunca muda. Serve para identificar a placa em log e inventário. Derivar chave dele é um erro clássico, porque público e constante são exatamente as duas propriedades que uma chave não pode ter.

Comandos da Fase 2 — primitivas

Opcode	Nome	Payload do pedido	Payload da resposta
`0x10`	`AES_ENC`	chave(32) || bloco(16)	bloco(16)
`0x11`	`AES_DEC`	chave(32) || bloco(16)	bloco(16)
`0x12`	`SHA256`	mensagem	digest(32)
`0x13`	`HMAC`	klen(1) || chave || mensagem	mac(32)
`0x14`	`RANDOM`	n(2), máximo 256	n bytes do CTR_DRBG
`0x15`	`SELFTEST`	vazio	máscara de falhas(1)

⚠ **`AES_ENC`, `AES_DEC` e `HMAC` recebem a chave em claro no payload**, e por isso só respondem em `UNINITIALIZED`. Não é convenção: é a máscara de estados na tabela de comandos. Um comando que aceita chave em claro não pode coexistir com chave de verdade no mesmo dispositivo — e no instante em que a LMK é carregada, os três param de responder sozinhos. A Fase 3 os **substitui** por versões que falam por handle de slot.

O `SELFTEST` é o único comando que responde em `TAMPERED`, e a exceção é deliberada: sem ele, um dispositivo que reprovou no boot ficaria mudo sobre *o que* reprovou, e o operador teria apenas um LED vermelho.

Comandos da Fase 3 — hierarquia de chaves

Opcode	Nome	Payload do pedido	Payload da resposta
`0x20`	`LMK_LOAD_COMPONENT`	n(1) ‖ componente(32)	kcv(3) ‖ carregados(1) ‖ estado(1)
`0x21`	`LMK_STATUS`	vazio	carregados(1) ‖ completa(1) ‖ kcv(3)
`0x22`	`GEN_KEY`	uso(2) ‖ alg(1) ‖ modo(1) ‖ exp(1)	handle(1) ‖ kcv(3)
`0x23`	`EXPORT_KEY`	handle(1)	key block X9.143 em ASCII
`0x24`	`IMPORT_KEY`	key block X9.143 em ASCII	handle(1) ‖ kcv(3)
`0x25`	`KEY_INFO`	handle(1)	uso(2) ‖ alg(1) ‖ modo(1) ‖ exp(1) ‖ len(1) ‖ kcv(3) ‖ usos(4)
`0x26`	`SET_STATE`	estado alvo(1)	estado atual(1)
`0x27`	`ENCRYPT`	handle(1) ‖ iv(16) ‖ dados	dados cifrados
`0x28`	`DECRYPT`	handle(1) ‖ iv(16) ‖ dados	dados em claro
`0x29`	`MAC_GENERATE`	handle(1) ‖ mensagem	tag(16)
`0x2A`	`MAC_VERIFY`	handle(1) ‖ tag(16) ‖ mensagem	vazio — o veredito é o status
`0x2B`	`DELETE_KEY`	handle(1)	slots livres(1)
`0x2C`	`KEY_FROM_COMPONENTS`	n(1) ‖ total(1) ‖ uso(2) ‖ alg(1) ‖ modo(1) ‖ exp(1) ‖ componente(32)	kcv(3) ‖ carregados(1) ‖ total(1) ‖ handle(1)
`0x2F`	`ZEROIZE`	vazio	estado atual(1)

Estados em que cada um responde. Não é convenção — é uma máscara na tabela de comandos, e é ela que faz a cerimônia ser uma escada de uma via.

Comando	Estados
`LMK_LOAD_COMPONENT`	só `UNINITIALIZED`
`SET_STATE`	só `AUTHORIZED`
`GEN_KEY`, `EXPORT_KEY`, `IMPORT_KEY`, `KEY_INFO`, `ENCRYPT`, `DECRYPT`, `MAC_GENERATE`, `MAC_VERIFY`, `DELETE_KEY`, `KEY_FROM_COMPONENTS`	só `OPERATIONAL`
`LMK_STATUS`	os três normais
`ZEROIZE`	**todos**, `TAMPERED` inclusive

Carregar os três componentes leva a `AUTHORIZED` e o `0x20` desaparece sozinho; ativar leva a `OPERATIONAL` e o `0x26` desaparece do mesmo jeito. Nenhum degrau se repete, e não há como descer sem apagar.

Quais exigem dual control, e a divisão diz mais que a lista:

exigem	`LMK_LOAD_COMPONENT`, `SET_STATE`, `ZEROIZE`, `KEY_FROM_COMPONENTS`
não exigem	`GEN_KEY`, `EXPORT_KEY`, `IMPORT_KEY`, `KEY_INFO`, `ENCRYPT`, `DECRYPT`, `MAC_GENERATE`, `MAC_VERIFY`, `DELETE_KEY`

Dual control é para **cerimônia**, não para operação. Carregar a chave mestra, ativar o dispositivo e apagar tudo são eventos raros, com gente na frente da placa. Gerar, exportar e importar chave é o que um HSM faz o dia inteiro — exigir dois dedos ali não aumentaria segurança nenhuma, só garantiria que ninguém usa o equipamento. E um controle que impede o uso legítimo é desligado no primeiro dia ruim.

O que protege os quatro de baixo é outra coisa, e é estrutural: a chave nunca sai em claro, o key block é autenticado sobre cabeçalho **mais** corpo, e `exportabilidade` decide quem pode sair.

⚠ **O `ZEROIZE` tem uma assimetria deliberada.** O comando exige dois operadores; o gatilho **automático** — autoteste reprovado — não exige ninguém. Se ele exigisse, bastaria não haver operador na sala para a chave sobreviver ao comprometimento.

Notas por comando:

- **`GEN_KEY`** — a chave vem do CTR_DRBG do dispositivo e **nunca existe fora da fronteira**. O host escolhe os metadados e recebe handle e KCV. É o contraste que a fase inteira ensina: o `AES_ENC` da Fase 2 recebia a chave *no payload*.
- **`EXPORT_KEY`** — o único comando que faz material de chave atravessar a fronteira, e ele atravessa embrulhado. Respeita `exportabilidade`: um slot marcado `'N'` devolve `NOT_EXPORTABLE`. Exportar o mesmo slot duas vezes dá blocos **diferentes**, porque o enchimento é aleatório — dois blocos idênticos denunciariam que a mesma chave saiu duas vezes.

- `IMPORT_KEY` — os metadados vêm **do bloco**, autenticados pelo MAC. Toda recusa devolve o mesmo `BAD_PARAM`: bloco malformado, hexadecimal inválido, MAC errado e comprimento impossível são indistinguíveis de fora. Distinguir em qual etapa a validação parou é o oráculo de padding clássico.
- `KEY_INFO` — metadados, nunca chave. Handle inválido e slot vazio devolvem o mesmo código: separar permitiria mapear o key store sem instalar nada.
- `ENCRYPT` / `DECRYPT` — usar a chave guardada, referida por **handle**. É o contraste que fecha a fase: os comandos da Fase 2 recebiam a chave no pedido; aqui vai um número de gaveta.

  AES-CBC com IV explícito, e não ECB — ECB para dados é o erro que a seção 16 usa como exemplo. O IV vem de quem chama, porque uma função que puxa entropia sozinha não é testável de forma determinística.

  O `modo` do slot decide: uma chave marcada `'E'` (só cifrar) recusa `DECRYPT` com `BAD_KEY_USE`. E `exportabilidade='N'` **não** impede usar — não poder sair é diferente de não poder trabalhar.

  ⚠ **É um oráculo de cifragem, e vale dizer.** Quem tem o handle cifra e decifra o que quiser sob aquela chave, em laço. Não há como não ser — é o serviço que um HSM presta. O que ele não entrega é a chave, e é para isso que o handle existe. O controle real está no `modo` e no log de auditoria.
- `MAC_GENERATE` / `MAC_VERIFY` — CMAC-AES sob a chave de um slot. Os modos de uso se dividem em **dois grupos que não se cruzam**: `E` / `D` / `B` cifram, `G` / `V` / `C` autenticam. Uma chave de cifra não assina, e uma de MAC não cifra — é assim que a confusão de tipo de chave se fecha.

  ⚠ `MAC_VERIFY` **devolve um bit**, no status. O dispositivo compara em tempo constante, do lado de dentro. Devolver a tag calculada para quem perguntou comparar entregaria 128 bits em vez de 1, e reabriria o canal lateral de tempo que a comparação interna existe para fechar.
- `DELETE_KEY` — apaga **um** slot, e **não pede dual control**. A assimetria com o `ZEROIZE` é deliberada: apagar um é reversível, porque o key block daquela chave continua existindo fora do equipamento. Apagar tudo não é.
- `KEY_FROM_COMPONENTS` — a cerimônia da chave mestra aplicada a uma chave de trabalho: cada custodiante entra com a sua parte, ninguém vê a chave inteira, e o equipamento monta por XOR do lado de dentro.

  É o único comando de operação que exige dual control, e por isso: é cerimônia, não operação. Aperto novo a cada componente.

  O KCV que volta é o **do componente**, nunca o do acumulado — é o que permite ao custodiante conferir que digitou o dele. E a resposta tem comprimento fixo, com handle zero enquanto a montagem não termina.

O `0x20` e o `0x26` exigem **dual control**: os dois botões pressionados no instante em que o frame chega, e um aperto *novo* a cada autorização (seção 28). São os únicos comandos do projeto cuja autorização não está no link do host — o que é o ponto inteiro deles.

O KCV que o `0x20` devolve é o do **componente**, não o da LMK acumulada. O `0x21` devolve o da LMK, e só quando ela está completa; enquanto incompleta, os três bytes vêm zerados, e a resposta mantém o comprimento fixo para que o tamanho do frame não anuncie nada.

Uma LMK **zerada** é recusada no terceiro componente com `BAD_PARAM`, e a cerimônia recomeça do componente 0 — não há como saber qual dos três estava errado. Acontece se o último componente for o XOR dos dois primeiros: cada um parece aleatório, e a soma é zero. LMK *fraca* (de pouca entropia) não é checada; a qualidade do componente é responsabilidade do custodiante.

Comando da Fase 4 — log de auditoria

Opcode	Nome	Pedido	Resposta	Estados
`0x2D`	`AUDIT_READ`	seq inicial (4)	próximo (4) ‖ continuar (4) ‖ até 16 registros de 16 bytes	todos menos `TAMPERED`

Cada registro: `seq(4) | comando(1) | estado(1) | argumento(1) | resultado(1) | reservado(4) | crc32(4)`. Comando `0x00` é o boot; resultado `0xFF` é "pendente", um comando que começou e não terminou.

Porta host — command set ASCII (Fase 5)

Tudo acima é o **console**. A porta **host** usa a mesma UART com mensagens ASCII, enquadradas pelo mesmo `LEN` de 2 bytes e **sem CRC**:

```
pedido     LEN(2) | cabeçalho(4) | comando(2) | campos
resposta   LEN(2) | cabeçalho(4) | resposta(2) | erro(2) | campos
```

O primeiro byte do corpo separa os protocolos: de `'0'` a `'~'` é ASCII, e qualquer outro é opcode binário. O cabeçalho é do host e volta igual; a resposta é o comando com o segundo caractere mais um.

A chave de trabalho vai **no comando**, como key block X9.143 sob a LMK. O comprimento do bloco sai do próprio cabeçalho dele. Dados vão como comprimento em 4 dígitos decimais seguido de hex.

Pedido	Resposta	Campos do pedido	Campos da resposta	Estados
`D0`	`D1`	—	estado(1) ‖ KCV da LMK(6) ‖ versão(6)	todos menos `TAMPERED`
`K0`	`K1`	uso(2) ‖ modo(1) ‖ exportabilidade(1)	key block ‖ KCV(6)	`OPERATIONAL`
`K2`	`K3`	key block	uso(2) ‖ alg(1) ‖ modo(1) ‖ exp(1) ‖ KCV(6)	`OPERATIONAL`
`C0`	`C1`	key block ‖ IV(32) ‖ dados	dados	`OPERATIONAL`
`C2`	`C3`	key block ‖ IV(32) ‖ dados	dados	`OPERATIONAL`
`M0`	`M1`	key block ‖ dados	MAC(32)	`OPERATIONAL`
`M2`	`M3`	key block ‖ MAC(32) ‖ dados	— (o veredito é o erro)	`OPERATIONAL`

Erros: `00` sem erro · `01` verificação falhou · `10` key block inválido · `11` o modo do bloco não permite · `15` dados inválidos · `16` parâmetro inválido · `20` estado não permite · `21` comando desconhecido · `22` mensagem malformada · `27` falha no log · `90` erro interno. Os códigos de comando e de erro são deste projeto.

No log de auditoria, um comando da porta host aparece com os dois caracteres dele nos campos `comando` e `argumento` (`K0` = `0x4B`, `0x30`) e o código de erro em decimal no `resultado`.

Códigos de status

Código	Nome	Significado
`0x00`	`OK`	
`0x01`	`BAD_CRC`	CRC não confere
`0x02`	`BAD_LEN`	`LEN` fora da faixa
`0x03`	`TIMEOUT`	frame incompleto, resincronizado
`0x10`	`UNKNOWN_CMD`	opcode não está na tabela
`0x11`	`BAD_PARAM`	tamanho ou conteúdo do payload
`0x12`	`NOT_IMPLEMENTED`	na tabela, sem implementação ainda
`0x20`	`WRONG_STATE`	comando não permitido neste estado
`0x21`	`NOT_AUTHORIZED`	falta dual control
`0x22`	`NOT_EXPORTABLE`	exportabilidade do slot proíbe
`0x23`	`NO_SLOT`	key store cheio
`0x24`	`BAD_KEY_USE`	o `modo` do slot proíbe a operação
`0x25`	`MAC_INVALID`	o MAC não confere
`0x26`	`STORE_FAIL`	fase 4: a flash não gravou; a operação foi desfeita
`0x27`	`LOG_FAIL`	fase 4: sem registro no log, o comando não executa
`0x30`	`SELFTEST_FAIL`	
`0x31`	`TAMPERED`	
`0xFF`	`INTERNAL_ERROR`	

Exemplo verificado em hardware

```
pedido   : 00 01 01 91 5D D8 C5
resposta : 00 05 00 50 4F 4E 47 FB 28 3D 2A
                  ^^  P  O  N  G
```

`91 5D D8 C5` é `zlib.crc32(b'\x00\x01\x01')`.

C. Pinagem

Fonte: esquemáticos QMTECH e verificação em hardware. Detalhes e procedência em `doc/pinout.md`.

Função	Pino	Estado
Clock 50 MHz	N11	verificado em hardware
Reset (SW1)	B7	esquemático; ativo baixo
UART RX / TX	T15 / T14	verificado em hardware
Dual control A (SW2)	M6	verificado em hardware; ativo baixo
Dual control B (SW5)	P6	verificado em hardware; ativo baixo
LEDs D1–D5	R6, T5, R7, T7, R8	verificados; **ativos baixos**; todos vermelhos
7 segmentos	T10, K13, P11, R11, R10, N9, K12, P9	`a` … `g`, `dp`; **acende com 0**
Dígitos (varredura)	T9, P10, T8	3 dígitos; **habilita com 1**

Armadilha registrada: com o gravador ligado existem **duas** portas seriais. O adaptador JTAG usado é um FT232H que também cria `/dev/ttyUSB*`, e costuma enumerar **antes** da placa. Escolher a porta por ordem alfabética acerta o cabo de gravação, e o sintoma é um timeout sem explicação. A ferramenta de host escolhe por identificador USB por causa disso.

Nenhuma pendência de pinagem. As três que existiam — cores dos LEDs, polaridade do display e ordem física dos botões — foram fechadas por medida em hardware, e duas delas mudaram o projeto:

- **Os cinco LEDs são vermelhos.** O requisito "LED vermelho para `TAMPERED`" está atendido e ao mesmo tempo vazio: **cor não distingue nada nesta placa**. Um indicador de estado tem de se separar por *posição* e *padrão* — e é o display que carrega a informação de verdade.
- **A polaridade do display estava invertida no código**, por palpite. O segmento acende com `0` e o dígito habilita com `1`; o toplevel supunha o contrário. Não aparecia porque, com os segmentos desligados, habilitar ou não os dígitos dá no mesmo — apareceria no primeiro estado exibido.

O detalhe que fecha o assunto: **um testbench conferia o valor errado e passou meses verde**, porque afirmava a suposição em vez de uma medida.

D. Reproduzir o trabalho

Dependências

```
git clone --recurse-submodules <url>

sudo apt install -y gcc-riscv64-unknown-elf picolibc-riscv64-unknown-elf
sudo apt install -y python3-serial openfpgaloader
```

Vivado 2026.1 (o `xsim` também é usado na simulação, por causa das primitivas Xilinx e do VHDL do NEORV32).

O compilador sozinho não basta: ele fornece apenas os headers freestanding, e o header do NEORV32 precisa de uma biblioteca C. Não há `libnewlib` para RISC-V nos repositórios Debian; picolibc é o equivalente.

Construir e testar

```
source /opt/AMD/2026.1/Vivado/settings64.sh

./scripts/sim.sh                # todos os testbenches; recompila o
                                # firmware sozinho se o C estiver mais novo
make -C fw image                # o build da FPGA depende desta imagem
vivado -mode batch -source scripts/build.tcl

./scripts/program.sh flash      # grava na SPI flash

python3 host/hsmtool.py selftest # sem placa: o codec do protocolo
python3 host/test_hsmtool.py     # sem placa: o transporte
python3 host/test_tr31.py        # sem placa: o key block (precisa de
                                 # `cryptography`)
python3 host/hsmtool.py ping
python3 host/hsmtool.py bench -n 10000
```

⚠ **`flash`, e não a RAM de configuração.** O firmware mora na Block RAM de instruções, cujo conteúdo inicial vem do bitstream. Configurar por JTAG pode deixar a placa com `Done = 1`, o clock travado e a CPU **sem executar uma instrução** — porque a inicialização das Block RAMs não foi aplicada. O sintoma é cruel: tudo indica sucesso e o dispositivo está mudo. Detalhes e discriminadores de falha em `doc/bancada.md`.

⚠ **`sim.sh` recompila o firmware quando o C está mais novo que a imagem.** Até isso existir, editar C e simular validava o **binário anterior** — e o modo como isso foi descoberto está na seção 28: uma sabotagem deliberada do código passou na simulação, porque o código sabotado nunca chegou a ser compilado.

Política de código de terceiros

Nunca editar `third_party/` diretamente: a mudança não fica guardada no repositório, é descartada por `git submodule update`, e quebra a procedência — o pin continua dizendo `v1.13.3` enquanto o bitstream contém outra coisa.

Ordem para mudar código externo:

1. **Configuração** (generic no wrapper) — resolve quase sempre
2. **Ponto de extensão projetado** — é o caso do CFS na Fase 2
3. **Patch** em `patches/`, aplicado pelo build
4. **Fork** e repontar o submódulo — só com patch que precise persistir

Detalhes em `doc/submodulos.md`. O espelho offline reproduzível dos cores externos sai de `./scripts/mirror-deps.sh`.

E. Operar o dispositivo

O apêndice D ensina a **construir**. Este ensina a **usar** — uma sessão inteira, do power-on até o dispositivo operacional, com o que cada resposta significa.

Tudo daqui é feito com `host/hsmtool.py`, que fala o protocolo do apêndice B pela UART do CP2102 (115200 8N1, a mesma porta USB que alimenta o core board).

E.1 Ligar e conferir

O bitstream mora na **flash SPI**, então a placa sobe sozinha na energização. Não há nada a carregar.

Antes de digitar qualquer coisa, olhe o display. Ele soletra o estado:

```
    U n i      UNINITIALIZED   sem chave mestra
    A u t      AUTHORIZED      LMK carregada, ainda não em serviço
    O P E      OPERATIONAL     em serviço
    t P r      TAMPERED        reprovou, e não sai daí por software
```

Isso é o dispositivo dizendo em que estado está **sem que ninguém pergunte** — e é a única informação que ele oferece de graça. Confirme depois pela serial, que é o canal com autoridade:

```
python3 host/hsmtool.py version
```

```
firmware : v0.1.0
estado   : UNINITIALIZED (0)
```

`UNINITIALIZED` é o estado de fábrica: o dispositivo funciona, mas não guarda chave nenhuma.

Antes de qualquer outra coisa, o autoteste. Ele já rodou no boot — o `SELFTEST` apenas o repete, e é assim que se confere que o módulo continua calculando certo *agora*, não só quando ligou:

```
python3 host/hsmtool.py post
```

```
AES-256               ok
SHA-256               ok
HMAC-SHA-256          ok
CTR_DRBG              ok
TRNG / health tests   ok
CMAC-AES-256          ok
key store             ok
key block X9.143      ok
```

Oito linhas, oito verdades diferentes.

As cinco primeiras são respostas conhecidas contra vetores oficiais (seção 11) — exceto a quinta, que são os **testes de partida** da fonte de entropia sobre um retrato de 1024 amostras brutas (seção 10).

As três últimas são de natureza diferente e vale distinguir, porque a norma distingue: **testes de função crítica**, não de algoritmo. Não existe "resposta conhecida" para instalar uma chave — existem propriedades que, se falharem, tornam o dispositivo perigoso *sem parecer quebrado*:

- **key store** — uma chave marcada como não exportável não sai; um slot apagado não responde; uma chave de cifrar não é aceita para decifrar; e a zeroização, depois de rodar, não deixou um byte diferente de zero na região de chaves;
- **key block X9.143** — um key block de procedência externa é desembrulhado e devolve a chave certa; um cabeçalho adulterado é recusado; e uma ida-e-volta fecha.

⚠ Sobre esse último vale uma ressalva de procedência que não aparece em nenhum outro: **o vetor dele não é do CAVP, e não há como ser.** O programa de validação do NIST valida *algoritmo*, e X9.143 é *formato*; a norma que traz o exemplo é paga. O que se usa é um valor conhecido de terceiros, fixado por commit e por hash. Está registrado em `vectors/MANIFEST.txt` em vez de dissimulado entre os demais.

⚠ **O autoteste zera a memória de trabalho.** O teste do key store instala e apaga chaves de verdade e termina com o store vazio, chave mestra inclusive. Um autoteste que poupasse a chave exercitaria um caminho que não é o do boot. Até a Fase 3, rodá-lo num dispositivo carregado apagava a LMK; desde a Fase 4 o dispositivo restaura tudo da flash em seguida e volta ao estado em que estava.

Se alguma reprovar, o dispositivo vai para `TAMPERED` e passa a atender **só** ao `SELFTEST`. Isso é o comportamento correto, e a exceção é deliberada: sem ela o operador teria apenas um LED vermelho e nenhuma informação sobre *o que* falhou.

E.2 O que dá para fazer antes de haver chave

Em `UNINITIALIZED` o dispositivo é uma caixa de primitivas. Estes comandos recebem a chave **no payload**, o que um HSM de verdade jamais aceitaria:

```
python3 host/hsmtool.py sha256 616263          # SHA-256 de "abc"
python3 host/hsmtool.py aes <chave-hex> <bloco-hex>
python3 host/hsmtool.py random -n 32           # bytes do CTR_DRBG
```

Eles existem para exercitar o hardware antes de existir key store, e **param de responder no instante em que houver LMK** — não por uma linha de código que os desligue, mas porque a máscara de estados deles diz `UNINITIALIZED` e o dispositivo não estará mais lá. Guarde isso: é a demonstração mais limpa de por que estado importa num HSM.

O `random` é o único dos quatro que continua funcionando depois. Ele não recebe chave nenhuma.

E.3 A cerimônia de LMK

A **Local Master Key** é a raiz da hierarquia (seção 7): é ela que embrulha todas as demais. Ela não é digitada por uma pessoa. Ela nasce de **três componentes**, cada um sob a guarda de um custodiante diferente, que se combinam por XOR dentro do dispositivo.

Por que XOR e por que três: nenhum componente isolado revela **nada** sobre a chave — nem um bit — e conhecer dois de três não ajuda. Três é prática operacional, não criptografia: dois custodiantes não dão margem se um faltar no dia, e mais de três transforma a cerimônia em logística.

O gesto físico. Cada componente exige dois botões da placa pressionados no instante em que o comando chega. São o **2º e o 5º** de uma fileira de cinco, cujo primeiro é o reset:

```
    [reset]  [ * ]   [   ]   [   ]   [ * ]
      SW1      SW2     SW3     SW4     SW5
```

O par mais afastado disponível, para dificultar apertar os dois com uma mão só. O `hsmtool.py` desenha esse mapa a cada pedido, porque ler silkscreen minúsculo no meio de uma cerimônia é como se aperta o botão errado.

E o dispositivo confirma. Aperte os dois: o **ponto decimal** do dígito da direita acende. Solte: apaga.

```
    U n i.        os dois botões apertados, autorização disponível
    U n i         não
```

Esse ponto é a resposta de bancada para "que botões?" — em vez de confiar num rótulo, aperte e veja o dispositivo concordar. Se acendeu, o comando seguinte vai ser autorizado; se não acendeu, seria recusado, e você descobre isso **antes** de gastar o comando em vez de depois.

Ele não vaza nada: quem está apertando os botões já está na frente da placa, e não há observador remoto para quem a informação seja novidade.

E exige um aperto **novo**: entre um componente e o seguinte, os dois têm de ser vistos **soltos**. Segurar os dois durante a cerimônia inteira carrega **um** componente, não três (seção 28).

```
python3 host/hsmtool.py lmk-status
```

```
componentes : 0 de 3
KCV da LMK  : -- (incompleta)
```

Agora cada componente, um de cada vez:

```
python3 host/hsmtool.py lmk-load 0 --random
```

O `--random` gera o componente **no host** e o imprime na tela. Isso é uma concessão de brinquedo, e o próprio comando avisa: material de chave na tela é exatamente o que um HSM existe para evitar. Num equipamento real cada componente nasce com o seu custodiante, num cartão ou num dispositivo de entrada dedicado. Para fornecer um componente existente, passe-o em hex no lugar de `--random`.

A ferramenta então pede o gesto e espera:

```
Carregar o componente 0 da LMK.
  SOLTE os dois botoes, depois SEGURE SW2 e SW5 juntos
  e tecle Enter sem soltar.
```

Segure os dois, tecle Enter sem soltar, e a resposta volta:

```
KCV do componente : 539062
componentes       : 1 de 3
estado            : UNINITIALIZED (0)
```

O KCV que volta é o do componente, não o da LMK. É o que permite ao custodiante conferir, ali, que digitou o dele e não o do vizinho. Sem esse passo, um componente trocado só apareceria no KCV final — quando já não dá para saber qual dos três estava errado. Confira contra o valor que o custodiante trouxe anotado; se não bater, **pare a cerimônia**.

Repita para os componentes `1` e `2`. Ao terceiro:

```
componentes       : 3 de 3
estado            : AUTHORIZED (1)
```

O estado muda no mesmo comando que completa a chave, e não num comando separado: *"tenho LMK"* e *"estou em AUTHORIZED"* precisam ser a mesma afirmação, ou o estado vira opinião.

```
python3 host/hsmtool.py lmk-status
```

```
componentes : 3 de 3
KCV da LMK  : 46F2FB
```

Anote esse KCV. Ele é a única coisa derivada da LMK que atravessa a fronteira, e é como se confere, em qualquer sessão futura, que o dispositivo tem a chave certa — sem que ninguém veja a chave. Três bytes dão uma colisão em 16 milhões: basta para pegar erro de digitação, e não basta para atacar.

Se `STATUS_NOT_AUTHORIZED` voltar, os botões não estavam apertados — ou estavam apertados desde a autorização anterior. Solte, aperte e repita. Essa recusa é a única prova de que o dual control existe de verdade: é o único comando do dispositivo cuja autorização não está no link do host.

E.4 Ativar

`AUTHORIZED` significa "tenho a raiz". `OPERATIONAL` significa "estou em serviço". A passagem é um ato de cerimônia, também com dual control:

```
python3 host/hsmtool.py activate
```

```
estado : OPERATIONAL (2)
```

Repare no que desapareceu. Tente agora:

```
python3 host/hsmtool.py aes <chave> <bloco>
```

```
dispositivo recusou: STATUS_WRONG_STATE (0x20)
```

O comando que aceitava chave em claro não existe mais neste estado. E a própria cerimônia também não se repete — não há caminho para trocar a chave mestra por cima da existente, o que seria substituir a raiz sem apagar o que ela protege. A escada é de **uma via só**, e descer exige apagar.

E.5 Os indicadores da placa

O display de 7 segmentos é o indicador que importa, e há um motivo concreto: os cinco LEDs desta placa são **todos vermelhos**. A cor não carrega informação nenhuma, só a posição — o requisito "LED vermelho para `TAMPERED`" está atendido e vazio.

O que mostra	Significado
`Uni` `Aut` `OPE` `tPr`	o estado da máquina (seção 8)
ponto decimal aceso	dual control satisfeito **neste instante**

Um detalhe de projeto que vale registrar: se os dois bits de estado chegarem corrompidos, o display mostra `tPr`. O `default` do decodificador é `TAMPERED`, e não `Uni` nem apagado — falhar para o lado seguro vale também para o painel. Um display que mostrasse "sem chave" quando não sabe seria pior que um display apagado.

E o que ele **nunca** vai mostrar: KCV, handle, qualquer coisa derivada de chave. Ótico é o único canal do dispositivo que não aparece numa captura de UART, então é o canal em que um vazamento passaria despercebido por mais tempo. O módulo recebe dois bits de estado e um de autorização, e não tem caminho nenhum até material de chave.

Os LEDs, que sobraram como indicadores grosseiros:

LED	Significado
D1	pisca a 1 Hz — o clock de 100 MHz está vivo. É **hardware**, independente da CPU
D2	aceso — o POST passou e o dispositivo está no laço de comandos
D5	aceso — `TAMPERED`

D1 ser hardware é deliberado: se o firmware travar, D1 continua piscando, e isso distingue "clock morto" de "firmware pendurado". Num dispositivo sem console, essa distinção é a diferença entre depurar e adivinhar.

O display, ao contrário, é dirigido pelo firmware — ele mostra o que a CPU diz. As duas coisas se complementam: **D1 prova que o hardware vive, o display prova que o firmware sabe onde está.** Display congelado com D1 piscando é firmware pendurado; os dois parados é clock morto.

Fora isso, o dispositivo é **mudo até ser perguntado**. Um terminal aberto na porta serial não mostra absolutamente nada, e esse é o comportamento correto: um módulo criptográfico que conversa sozinho está contando alguma coisa a alguém.

E.6 Trabalhar com chaves

Depois de `OPERATIONAL`, **nenhum comando pede botão** — e isso é o ponto, não uma economia. A cerimônia acabou; o que vem agora é operação.

```
hsmtool.py gen-key --uso D0 --modo B --exp E
#   handle : 1
#   KCV    : 7ED838
```

A chave veio do gerador do dispositivo e **nunca existiu fora da fronteira**. O que voltou foi um handle e três bytes de KCV. Compare com o `aes` da Fase 2, onde a chave ia no pedido: é a mesma diferença entre um cofre e uma gaveta.

```
hsmtool.py export-key 1
#   D0144D0AB00E0000B82679114F470F54...
```

São 144 caracteres de texto: dezesseis de cabeçalho legível, o corpo cifrado, e o MAC. Exporte de novo e o bloco será **diferente** — o enchimento é aleatório, e dois blocos idênticos denunciariam que a mesma chave saiu duas vezes.

```
hsmtool.py import-key D0144D0AB00E0000...
#   handle : 2
#   KCV    : 7ED838      <- o mesmo
```

Mesmo KCV, outro handle: a chave voltou inteira. E o experimento que vale a pena fazer é o negativo — troque **um caractere** do bloco, em qualquer posição, e tente importar. O dispositivo recusa. O caractere na posição 11 é a exportabilidade; reescrevê-lo à mão é literalmente o ataque que o MAC sobre o cabeçalho existe para impedir.

```
hsmtool.py gen-key --exp N
hsmtool.py export-key 3
#   dispositivo recusou: STATUS_NOT_EXPORTABLE
```

Uma chave marcada `'N'` não sai. Não por convenção: existe **um único caminho** para os bytes deixarem um slot, e é ele que consulta o campo.

```
hsmtool.py key-info 1
#   uso D0 · algoritmo A · modo B · exportabilidade E · 32 bytes
#   KCV 7ED838 · usos 0
```

Metadados, nunca chave. Não existe "me devolva o slot inteiro".

E finalmente **usar** a chave — que é o que separa um cofre de um depósito:

```
hsmtool.py encrypt 1 <iv 16 bytes> <dados múltiplos de 16>
hsmtool.py decrypt 1 <mesmo iv>    <o criptograma>
```

A chave é referida por **handle**. Compare com o que a Fase 2 fazia: lá a chave ia dentro do pedido. Aqui vai um número de gaveta, e o material nunca atravessa a linha.

O experimento que fecha o assunto: exporte uma chave, reimporte, e cifre o **mesmo bloco com o mesmo IV** usando os dois handles. Os criptogramas têm de ser idênticos — é a prova de que a chave voltou bit a bit, e é bem mais forte que comparar os três bytes do KCV.

E o negativo, que ensina mais:

```
hsmtool.py gen-key --modo E        # 'E' = só cifrar
hsmtool.py decrypt <handle> ...    # -> BAD_KEY_USE
```

Confusão de tipo de chave é a origem de uma família inteira de ataques de API (seção 15). A defesa é o campo `modo`, e a verificação vive num lugar só — dentro do key store, não espalhada pelos comandos.

⚠ Uma distinção que confunde: `exportabilidade='N'` **não** impede usar. Impede **sair**. Uma chave que nunca sai e trabalha o dia inteiro é o caso mais comum de uma chave bem configurada.

E autenticar, que é o outro serviço:

```
hsmtool.py gen-key --uso M0 --modo C --exp E   # 'C' = gerar e verificar MAC
hsmtool.py mac 5 <mensagem hex>
hsmtool.py mac-verify 5 <tag> <mensagem>       # "MAC confere"
```

O veredito vem do **status**, não do payload: o equipamento compara e diz sim ou não. Devolver a tag calculada para você comparar entregaria 128 bits em vez de um, e é o tipo de conveniência que abre canal lateral.

E repare no `--modo C`. Os modos se dividem em **dois grupos que não se cruzam**:

grupo	valores	o que faz
cifra	`E` `D` `B`	`encrypt` / `decrypt`
MAC	`G` `V` `C`	`mac` / `mac-verify`

Tente `mac` numa chave `--modo B` e veja `BAD_KEY_USE`. Tente `encrypt` numa `--modo C` e veja o mesmo. Essa separação não é burocracia de campo — é a defesa contra **confusão de tipo de chave**, que é a origem de uma família inteira de ataques de API (seção 15).

E.7 Liberar um slot, e montar uma chave a várias mãos

O key store tem dezesseis slots. Para devolver um:

```
hsmtool.py delete-key 5
#   apagado. slots livres: 12
```

Sem dual control, ao contrário do `zeroize`. A razão é que apagar um slot é **reversível**: se você guardou o key block daquela chave, reimportar devolve tudo. Apagar o equipamento inteiro não é reversível, e por isso pede duas pessoas.

E a operação que fecha o capítulo — montar uma chave que **ninguém conhece inteira**:

```
hsmtool.py comp-load 0 2 --random --uso K0 --modo B --exp E
hsmtool.py comp-load 1 2 --random --uso K0 --modo B --exp E
#   handle : 6  <- chave montada e instalada
```

É a cerimônia da chave mestra aplicada a uma chave de trabalho. Cada custodiante entra com a sua parte, sob dual control, e o equipamento combina por XOR **do lado de dentro**. É assim que uma chave combinada entre duas instituições entra num HSM sem que nenhuma das duas a conheça.

Três detalhes que valem reparar:

- **É o único comando de operação que pede os dois botões.** Os outros são trabalho; este é cerimônia.
- **O KCV que volta é o do componente**, não o da chave em construção. Serve para o custodiante conferir a parte dele. O do acumulado seria um oráculo sobre a chave que ainda está sendo montada.
- **Começar pelo componente 0 reinicia a montagem.** É como se abandona uma cerimônia que saiu errada, sem precisar de um comando para isso.

E o comando que desfaz tudo:

```
hsmtool.py zeroize      # com os dois botões
```

Apaga os 16 slots e a LMK, **e confere que apagou** antes de dizer que apagou. Funciona em qualquer estado — inclusive em `TAMPERED`, e ali ele apaga a chave sem tirar o dispositivo de `TAMPERED`: um HSM que se cura de tamper não detectou tamper nenhum.

E.8 Desligar, religar e ler o log *(fase 4)*

```
# depois da cerimônia e de gerar chaves: desligue e ligue a placa
python3 host/hsmtool.py version
#   estado   : OPERATIONAL (2)      <- sem cerimônia
python3 host/hsmtool.py lmk-status
#   KCV da LMK  : (o mesmo de antes)
python3 host/hsmtool.py key-info 1  # mesmo handle, mesmo KCV

python3 host/hsmtool.py audit
#      0  BOOT                Uni  sem registro persistente   OK
#      1  LMK_LOAD_COMPONENT  Uni  arg=0x00                   OK
#    ...
#     14  BOOT                OPE  restaurado                 OK
```

Cada linha do `audit` é um comando, gravado **antes** de executar. A coluna de estado é o estado em que o dispositivo estava quando o comando chegou. Um `GEN_KEY` tentado em `Uni` aparece com o resultado `WRONG_STATE`: tentativas recusadas também entram.

O `post` continua zerando a memória de trabalho, mas agora restaura tudo da flash em seguida, e o dispositivo volta ao estado em que estava. Só o `zeroize` apaga de vez: ele limpa a LMK e as chaves da flash e mantém o log, que é o registro de quem zeroizou.

E.9 O que ainda não existe

Honestidade sobre o estado do projeto, para que ninguém procure um comando que não foi escrito:

- **A LMK sobrevive ao desligamento, mas não está protegida.** Desde a Fase 4 ela fica na flash, que o projeto *trata* como memória segura. Quem tiver um gravador SPI a lê. É uma decisão didática diante do hardware disponível, explicada no §29.
- **Não há anti-rollback.** Regravar a flash com uma imagem antiga faz uma chave apagada voltar, e o dispositivo não percebe.
- **Não há exportação em formato legado.** Só em key block X9.143. Por isso `exportabilidade='S'` se comporta como `'E'` — e está certo: na norma, `'S'` é o valor *mais permissivo*, que libera também formatos legados (criptograma simétrico, embrulho RSA). Como eles não existem aqui, `'S'` e `'E'` liberam o mesmo caminho.
- **A exportação não é qualificada.** Aqui o campo é praticamente booleano e a chave que embrulha é sempre a mestra. No modelo comercial se diz sob *qual* chave a exportação pode acontecer, e para qual zona.
- **O log de auditoria detecta corrupção, não adulteração.** O CRC de cada registro pega um bit trocado por acidente; quem editar a flash de propósito recalcula o CRC.
- **`hsmtool keycycle` precisa da LMK em claro**, o que um HSM de verdade nunca permitiria. Serve para as duas implementações do formato de key block se conferirem; é bancada, não operação.

F. Leitura

Normas

- **FIPS 140-3** e ISO/IEC 19790 — requisitos de módulo criptográfico
- **NIST SP 800-90A/B/C** — DRBG, fontes de entropia, construções
- **ANSI X9.143** (sucessor do TR-31) — key blocks
- **PCI PIN Security Requirements** e **PCI PTS HSM** — de onde vêm dual control e split knowledge como exigência

Ataques

- Bond, M. — *Attacks on Cryptoprocessor Transaction Sets* (2001)
- Bond, M. e Zieliński, P. — *Decimalisation Table Attacks for PIN Cracking*

2003.

- Clulow, J. — *On the Security of Real-World PIN Processing* (2003)
- Boneh, DeMillo e Lipton — *On the Importance of Checking Cryptographic Protocols for Faults* (1997) — o ataque Bellcore
- Kocher, P. — *Timing Attacks* (1996) e, com Jaffe e Jun, *Differential Power Analysis* (1999)
- Piret e Quisquater — análise diferencial de falhas em AES (2003)

Livros

- Anderson, R. — *Security Engineering*. Os capítulos sobre APIs de segurança e sobre segurança de hardware são a melhor introdução ao assunto da Parte

  III.

- Maes, R. — *Physically Unclonable Functions*. Para o experimento da Fase 6.

Ferramentas e cores usados

- **NEORV32** — processador RISC-V em VHDL, `github.com/stnolting/neorv32`
- **secworks/aes** e **secworks/sha256** — cores criptográficos para a Fase 2
- **openFPGALoader** — gravação por JTAG

Este documento acompanha o repositório `hsm-a7`. A Parte V reflete o estado ao fim da Fase 1, validada em hardware. As Partes I a IV são independentes do projeto e valem por si.